



Federal Office
for Information Security

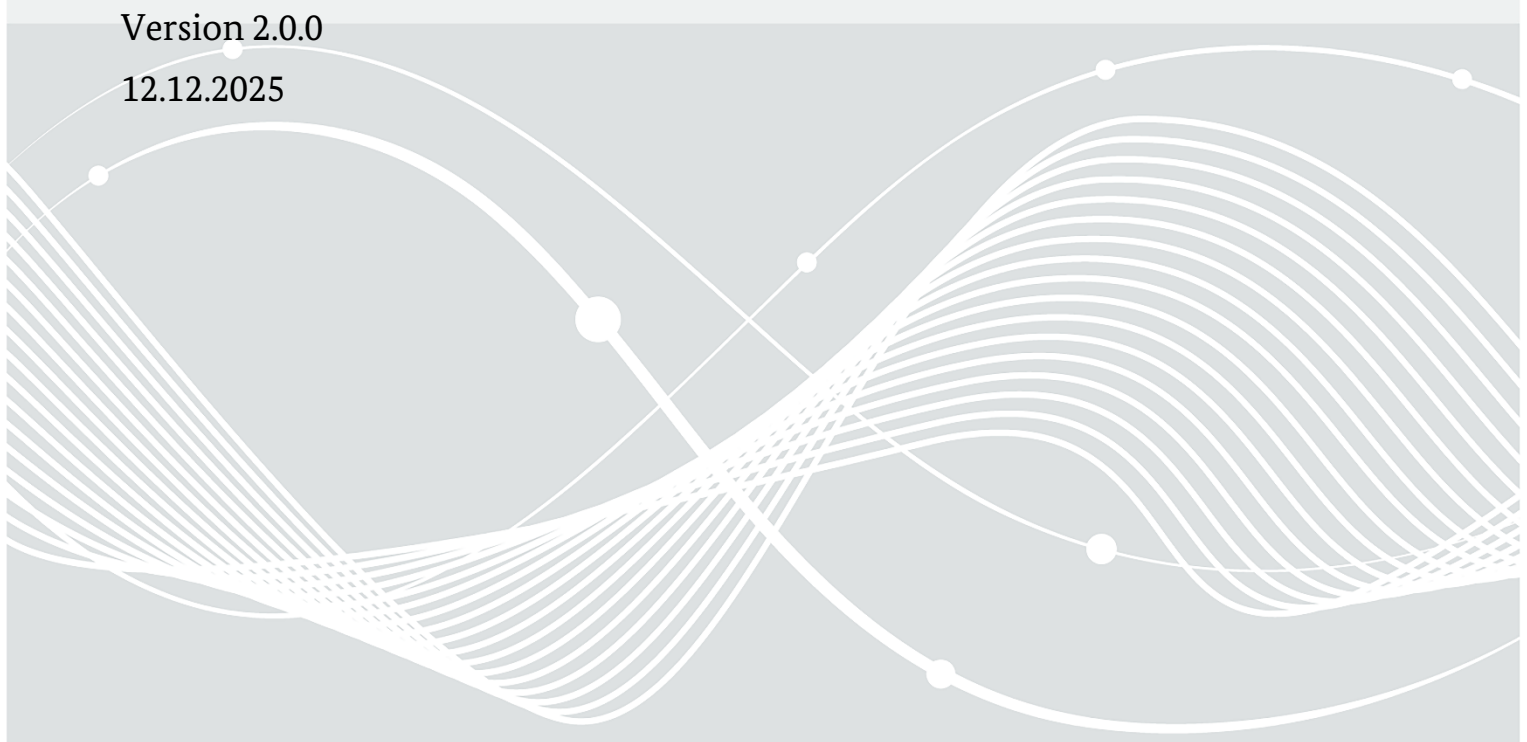
Inspection Specification BSI TR-03145-TS

Part 1: Generic requirements for a Certification Authority in a Public Key Infrastructure with security level 'high', Version 2.0.0

Part 4: Specific requirements for a Certification Authority in a Public Key Infrastructure for the Extended Access Control of the German Official Travel Documents according to BSI TR-03110, Version 2.0.0

Version 2.0.0

12.12.2025



Federal Office for Information Security
P.O. Box 20 03 63
53133 Bonn
Tel.: +49 22899 9582-0
E-Mail: eID@bsi.bund.de
Internet: <https://www.bsi.bund.de>
© Federal Office for Information Security 2025

Table of Contents

1	Introduction.....	5
1.1	Scope and structure of this document	5
1.2	Concept and approach of the Inspection Specification	5
1.2.1	Assignments	7
1.2.2	Notation.....	7
1.3	Scope of the Audit.....	7
2	General requirements for Certification Authorities.....	9
2.1	Cryptographic measures	9
2.2	Certification practice statement and certificate policy management.....	10
2.2.1	Certificate policy management.....	11
2.2.2	Certification practice statement management.....	15
2.2.3	Requirements for relying parties and subscribers of the CA	17
2.3	Information security policy.....	18
2.4	Asset classification and management.....	20
2.5	Human resources security.....	21
2.6	Physical and environmental security	23
2.7	Operational security.....	26
2.8	Access control	29
2.9	System acquisition, development and maintenance	32
2.10	Business continuity management.....	33
2.11	Monitoring, conformance and compliance	35
2.12	Audit journal security and archiving	35
2.13	Controlled CA termination	41
3	Key life cycle management.....	43
3.1	CA key life cycle management.....	43
3.1.1	CA key generation.....	44
3.1.2	CA key storage, backup, and recovery	46
3.1.3	CA public key distribution	48
3.1.4	CA key usage	48
3.1.5	CA key archival and destruction.....	50
3.1.6	CA key compromise.....	51
3.2	Subject key life cycle management.....	52
3.2.1	Subject key generation and distribution	53
3.2.2	Subject key storage, backup and recovery	57
3.2.3	Hardware token life cycle management (if supported).....	60
3.2.4	Subject key archival and destruction (if supported)	63

4	Certificate life cycle management	65
4.1	Subject registration.....	65
4.2	Certificate renewal (if supported).....	68
4.3	Certificate rekey.....	71
4.4	Certificate issuance.....	72
4.5	Certificate distribution.....	75
4.5.1	Directory Service (if supported)	76
4.6	Certificate changeover (if supported)	77
4.7	Certificate revocation	80
4.8	Certificate suspension (if supported)	85
4.9	Revocation status information service.....	89
4.10	Validation Model.....	92
	Bibliography	93

1 Introduction

The document at hand serves as the inspection specification for an auditor concerning a Certification Authority (CA) in a Public Key Infrastructure (PKI) with security level 'high'. This document contains lists for coordinating checks and actions to be undertaken by an auditor and thus, provides a structured approach to check if a Certification Authority in a Public Key Infrastructure fulfils all requirements for a secure CA operation as defined in (BSI-TR-03145-1).

The key words “MUST,” “MUST NOT,” “REQUIRED,” “SHALL,” “SHALL NOT,” “SHOULD,” “SHOULD NOT,” “RECOMMENDED,” “MAY,” and “OPTIONAL” in this document are to be interpreted as described in (RFC2119). Irrespective of capitalisation, the same holds for all referenced “control procedures” of (ISO27099).

1.1 Scope and structure of this document

The document at hand represents the inspection specification for the following parts of the Secure CA Operation series (BSI-TR-03145):

- (BSI-TR-03145-1) compiles “Generic requirements for a Certification Authority in a Public Key Infrastructure with security level 'high'”.
- (BSI-TR-03145-4) profiles “Specific requirements for a Certification Authority in a Public Key Infrastructure for the Extended Access Control of the German Official Travel Documents according to (BSI-TR-03110)”.

If necessary, the generic requirements of (BSI-TR-03145-1) are adapted to a specific application context in a separate Technical Guideline but as part of the superior Secure CA Operation series. Thereby, an application specific Technical Guideline of the Secure CA Operation series defines only the differences between the generic and the application specific requirements. That means that for a requirement of an application specific Technical Guideline the following three cases exist:

- a) the application specific requirement is a refinement of the corresponding, generic requirement from (BSI-TR-03145-1).
- b) the application specific requirement is a supplement to the generic requirements of (BSI-TR-03145-1). That means that the application specific requirement is a ‘new’ requirement and that it is not addressed by (BSI-TR-03145-1).
- c) the application specific requirement declares a generic requirement from (BSI-TR-03145-1) not applicable to that specific application context.

In order to be compliant with such an application specific part, a CA SHALL completely fulfil all application specific requirements as well as all requirements from (BSI-TR-03145-1) – unless explicitly declared not applicable in the application specific part. This means that in this case the CA SHALL fulfil

- all refined requirements according to a),
- all new requirements according to b),
- all generic requirements from (BSI-TR-03145-1) except those explicitly declared not applicable according to c) or already superseded according to a).

In order to allow the parallel usage of the document at hand and the corresponding Technical Guideline/Guidelines, this document mainly follows the structure of the corresponding version of (BSI-TR-03145). Furthermore, the notation of the requirements from (BSI-TR-03145) and from the application specific Technical Guideline/Guidelines is re-used here.

1.2 Concept and approach of the Inspection Specification

This chapter describes the usage and notations of the document at hand in detail.

The inspection specification is presented in table form. These tables are divided into 2 parts which are highlighted in cyan and gray, respectively.

The first part of the table is highlighted in cyan. This part describes and structures the actions that SHALL be performed by an auditor in order to check compliance of a CA with (BSI-TR-03145-1) and the corresponding application-specific part, if applicable. This first part of the table includes the following columns from left to right which cover all requirements for the secure CA operation according to the corresponding Technical Guideline/Guidelines:

- **1st column (“Requirement”)**: refers to the requirement which is covered by this action.
- **2nd column (“TR-Part”)**: specifies the part of the Secure CA Operation series the referred requirement stems from. If the entry is “1”, this requirement stems from (BSI-TR-03145-1). In this case, this action has to be performed by an auditor in any case. Other values correspond to application specific parts, e.g. “4” refers to (BSI-TR-03145-4). If the entry corresponds to an application specific part this action has to be performed only if the CA has to be checked according to that particular application specific Technical Guideline.
- **3rd column (“Inspection”)**: describes the action that SHALL be performed by an auditor.

The second part of the table is highlighted in gray and SHALL be filled in by the auditor to ensure and document a structured inspection of a CA. These 3 columns correspond to the actions, which an auditor SHALL perform during the inspection of a CA. The order of the actions by the auditor correspond to the order of the columns from left to right:

- **4th column (“CA Documentation”)**: The auditor SHALL identify the parts of documentation provided by the CA, which deal with the requirements and the inspection actions defined in the underlying row. All documents used by the auditor for the specific action SHALL be listed.
- **5th column (“Measures identified by the auditor”)**: Based on the CA’s documentation from the previous column, the auditor SHALL identify and document the measures which are provided by the CA in order to implement the requirements that are addressed by the first column (“Requirement”) of the underlying row. Those documented measures SHALL be inspected and evaluated during the inspection of the CA.
- **6th column (“Verdict and Explanations by the Auditor”)**: This column SHALL contain the verdict of the auditor concerning the completeness and effectiveness of the measures that are implemented by the CA in order to fulfil the requirements that are addressed by the first column (“Requirement”) of the underlying row.

The auditor SHALL state the verdict by marking one of the three given options.

Note: For the sake of transparency and accountability, the auditor SHALL give reasons for the verdict as follows: While identifying the measures of the CA based on the CA’s documentation (cf. column 3 and 4), the auditor SHALL note questions and remarks which showed up during this step in the corresponding column. These questions and remarks SHALL be checked by the auditor during the inspection at the CA. Of course, if additional questions occur during the inspection of the CA, they SHALL be noted and checked by the auditor as well. Only if all questions and remarks of one row are checked (completeness) and are evaluated with a positive result by the auditor (effectiveness), the requirement is covered by the CA and the auditor can give a positive verdict.

There are different background colours in the tables below that represent the following case:

- Yellow: These parts refer directly to the section and paragraphs of (ISO27099) and its corresponding requirements that need to be checked by the auditor
- Orange: These parts describe the audit requirements referring to (BSI-TR-03145-4)

1.2.1 Assignments

Several requirements contain assignments. For these assignments, the CA **MUST** clearly define which specific security measures, information or time periods are applicable and used to fulfil the requirement. Assignments represent cases in which own solutions may be added.

For all assignments, the auditor **SHALL** note the assigned values in the audit report. For example, for requirement 4.7.A2 the auditor **SHALL** note in the audit report how many hours the completion of the revocation process takes at most, e.g. 36 hours.

1.2.2 Notation

The following notation is used in this document:

The enumeration (i), (ii), (iii), ... is used for a list with different aspects where each aspect has to be inspected by the auditor.

A list indexed with a), b), c), ... indicates different cases. The auditor has to expound which case is relevant for the underlying evaluation. Subsequently the auditor has to check the selected case.

Further, nested notation are also used. For example:

- a) case A
 - (i) aspect A1
 - (ii) aspect A2
 - (iii) aspect A3
- b) case B
 - aspect B1

If case A is valid, the auditor has to check the aspects A1, A2, and A3. Otherwise B1 has to be checked.

1.3 Scope of the Audit

Part 1 of (BSI-TR-03145) defines requirements for the secure operation of a single CA in a PKI. This CA **SHALL** be uniquely identified in its own certificate as subject. Furthermore, its relationship within the PKI **SHALL** be clearly specified. This **SHALL** consist of a complete description of:

- all CAs the PKI consists of whereas these CAs are all uniquely identified in their certificate as subject,
- the PKI hierarchy, and
- all other PKI components or services that may be relevant for the security of the CA, such as for example Registration Authority, Directory Service or CRL Signer (if supported).

However, an audit according to Part 1 or other application specific parts **MAY** be performed for more than one single CA within the same PKI or for all CAs within the same PKI. The scope of the audit **SHALL** be described by means of the following table:

No.	Question	Declarations of the auditor
1	Has this audit been performed for a single CA?	☐ Yes ☐ No
2	For which part of the (BSI-TR-03145) series has this audit been performed?	☐ Part 1 ☐ Part 4

No.	Question	Declarations of the auditor
3	Based on which version of the Technical Guide this audit has been performed (e.g. BSI TR-03145-1 Version 2.0.0)?	
4	Description of the audited CA. Note: If more than one single CA is in the scope of the audit (see question 1 above), this question has to be answered once for each CA that is in the scope of the audit.	
4a	How is the audited CA identified in their certificate as subject (e.g. Root-CA-01)?	
4b	What is the type of the audited CA?	☐ root-CA ☐ sub-CA
5	Description of the CA's relationship within the PKI. Note: If more than one single CA is in the scope of the audit (see question 1 above), this question may have to be answered more than once depending on the audit scope.	
5a	List all CAs as identified in their certificate as subject the PKI consists of.	
5b	Briefly describe the PKI hierarchy.	
5c	Are there other PKI components or services that may be relevant for the security of the CA, such as for example Registration Authority, Directory Service or CRL Signer?	☐ No ☐ Yes If Yes, which ones:

If more than one CA is in the scope of the audit, an auditor SHALL evaluate all these CAs (and their relationships) and SHALL document the audit results in the inspection specification. For example, "Measures identified by the Auditor" may apply to all CAs in the scope of the audit or may differ. The same holds for "Verdict and Explanations by the Auditor". An auditor's verdict may be apply to all CAs in the scope of the audit or may differ. **The audit report SHALL clearly reflect these differences or similarities.**

2 General requirements for Certification Authorities

2.1 Cryptographic measures

The use of inappropriate cryptographic algorithms or parameters facilitates the compromise of certificates, signatures, hashes or encryption. Therefore, the CA shall ensure that appropriate cryptographic algorithms and parameters are used. The algorithms and parameters shall comply with the current state of the art and shall be based on well-known Technical Guidelines and standards such as for example (BSI-TR-03116), (BSI-TR-02102).

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
2.1A1	1	Check that the CA ensures that the cryptographic algorithms and their parameters comply with the newest editions of the following documents: [assignment: technical guidelines or standards for cryptographic algorithms and recommended key lengths]. Check that this document is appropriate for the business case of the CA. Check that the CA ensures to check the cryptographic algorithms and their parameters referring to the newest editions: (i) Each time a cryptographic algorithm is newly implemented. (ii) When an incident of a used algorithm becomes public. (iii) Regularly, in a period of [assignment: number of days, weeks or months].			☐ Pass ☐ Fail ☐ Not applicable

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
	4	Check that the CA ensures that the cryptographic algorithms and their parameters comply with the newest editions of (BSI-TR-03116-2). Check that the CA ensures to check the cryptographic algorithms and their parameters referring to the newest editions: (i) Each time a cryptographic algorithm is newly implemented. (ii) When an incident of a used algorithm becomes public. (iii) Regularly, in a period of [assignment: number of days, weeks or months].			☐ Pass ☐ Fail ☐ Not applicable

2.2 Certification practice statement and certificate policy management

This Section refers to Section 7.2 of (ISO27099) and addresses requirements concerning both, Certificate Policy and Certification Practice Statement. With respect to Certificate Policy and Certification Practice Statement, the following requirements apply:

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
2.2A1	1, 4	Check that CP and CPS are part of the documentation which is maintained within the ISMS.			☐ Pass ☐ Fail ☐ Not applicable

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
2.2A2	1, 4	Check that the CPs and CPSs within the PKI are compliant. If the audited CA is issuing certificates to a CA, check that the audited CA ensures that CP and CPS of the subscribing CA are consistent with its own CP and CPS. If the audited CA is a subscribing CA (i.e. the CA to be certified is not a Root-CA), check that the audited CA ensures that its own CP and CPS are consistent with CP and CPS of the issuing CA.			☐ Pass ☐ Fail ☐ Not applicable

2.2.1 Certificate policy management

Control procedures referenced in this Section refer to Section 7.2.1 of (ISO27099). In order to provide an adequate Certificate Policy, the following control procedures SHALL be fulfilled as requirements:

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
(1) from Section 7.2.1	1, 4	Check that the final authority, responsible for defining and approving certificate policies is clearly defined.			☐ Pass ☐ Fail ☐ Not applicable
(4) from Section 7.2.1	1, 4	Check that the CA maintains procedures for keeping the affected parties informed of any changes to its certificate policies and makes this available to the affected parties.			☐ Pass ☐ Fail ☐ Not applicable

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
(6) from Section 7.2.1	1, 4	Check that Certificate policies are approved by the CA in accordance to section 7.2.1 (6) of ISO 27099.			☐ Pass ☐ Fail ☐ Not applicable
(7) from Section 7.2.1	1, 4	Check that the CA makes available its certificate policies to all appropriate subscribers and relying parties.			☐ Pass ☐ Fail ☐ Not applicable
2.2.1A1	1, 4	Check that the CA's CP includes a reference to a contact person of the CA.			☐ Pass ☐ Fail ☐ Not applicable
2.2.1A2	1	Check that the key and certificate management life cycle processes of the CA are specified comprehensively in the CA's CP. Check that at least the following aspects are covered: • reference to a document owner for CP related issues • unique document identification for further reference, i.e. by exact document title, version and unique policy identifier for reference in certificates issued by the CA • limitations concerning subscribers of the PKI (e.g. company or administration specific PKIs) • application context of the PKI • description of subscriber registration procedures including specification of registration data, requirements for data transmission, and description of verification procedures of the CA or RA			☐ Pass ☐ Fail ☐ Not applicable

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
		• subscriber obligations (e.g. requirements on subscriber key stores and application environment) • specification of certificate profiles • validation model of the PKI, need of certificate validation by checking signature and fingerprints • certificate revocation procedures including revocation reasons, revocation authorization, revocation application mechanisms (if supported) • certificate status information services ○ CRLs (if supported) ○ OCSP (if supported) • directory service (if supported) • key lifecycle security measures • certificate renewal procedures (if supported) • CA termination • CP update procedures			
	4	Check that the key and certificate management life cycle processes of the CA are specified comprehensively in the CA's CP. Check that at least the following aspects are covered: • reference to a document owner for CP related issues			☐ Pass ☐ Fail ☐ Not applicable

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
		• unique document identification for further reference, i.e. by exact document title, version and unique policy identifier for reference in certificates issued by the CA • limitations concerning subscribers of the PKI (e.g. company or administration specific PKIs) • application context of the PKI • description of subscriber registration procedures including specification of registration data, requirements for data transmission, and description of verification procedures of the CA or RA • subscriber obligations (e.g. requirements on subscriber key stores and application environment) • specification of certificate profiles and request format • validation model of the PKI, need of certificate validation by checking signature and fingerprints • certificate revocation procedures including revocation reasons, revocation authorization, revocation application mechanisms (if supported) • certificate status information services ○ CRLs (if supported) ○ OCSP (if supported)			

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
		• directory service (if supported) • key lifecycle security measures • CA termination • CP update procedures			

2.2.2 Certification practice statement management

Control procedures referenced in this Section refer to Section 7.2.2 of (ISO27099). In order to provide an adequate Certification practice statement, the following control procedures SHALL be fulfilled as requirements:

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
(1) from Section 7.2.2	1, 4	Check that the CA's control processes, as described in the CA's CPS, is fully compliant with the requirements of the CP.			☐ Pass ☐ Fail ☐ Not applicable
(2) from Section 7.2.2	1, 4	Check that the CA ensures that a CPS is in place, describing at least the requirements as defined in section 7.2.2 (2) of ISO 27099. The auditor must check each requirement listed in section 7.2.2 (2), thus the enumeration (a), (b), (c) is substituted by (i), (ii), (iii) according to this TS.			☐ Pass ☐ Fail ☐ Not applicable
(3) from Section 7.2.2	1, 4	Check that the CA has a review and approval process for its CPS, including any changes. Check that the responsibilities for maintaining the CPS are clearly defined.			☐ Pass ☐ Fail ☐ Not applicable

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
(4) from Section 7.2.2	1, 4	Check that the CA provides its CPS to all appropriate parties.			☐ Pass ☐ Fail ☐ Not applicable
(5) from Section 7.2.2	1, 4	Check that the CA ensures to revise its CPS according to the requirements as defined in section 7.2.2 (5) of ISO 27099.			☐ Pass ☐ Fail ☐ Not applicable
(6) from Section 7.2.2	1, 4	Check that the CA provides revisions to the CA's CPS to all appropriate parties.			☐ Pass ☐ Fail ☐ Not applicable
(7) from Section 7.2.2	1, 4	Check that the CA's CPS contains an explanation of all controls as defined in section 7.2.2 (7) of ISO 27099. All controls shall be checked by the auditor, thus the enumeration from (a) to (f) of section 7.2.2 (7) is substituted by (i) to (vi) according to this TS.			☐ Pass ☐ Fail ☐ Not applicable
(8) from Section 7.2.2	1, 4	Check that the CA's controls are described in the CPS.			☐ Pass ☐ Fail ☐ Not applicable
(9) from Section 7.2.2	1, 4	Check that the CA's CPS (i) is defined by the CA, (ii) approved by management of the CA, (iii) published and communicated to employees and relevant external parties.			☐ Pass ☐ Fail ☐ Not applicable
(11) from Section 7.2.2	1, 4	Check that the CA remains responsible for writing and maintaining the CPS, in case the CA delegates some of its services or functions to separate component service providers.			☐ Pass ☐ Fail ☐ Not applicable

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
2.2.2A1	1, 4	Check that the CPS includes a reference to a document owner responsible for the document management.			☐ Pass ☐ Fail ☐ Not applicable
2.2.2A2	1, 4	Check that CPS includes a section with document identification of the CPS for further reference, i.e. by exact document title, version and unique policy identifier of the CP which the CPS is corresponding to.			☐ Pass ☐ Fail ☐ Not applicable
2.2.2A3	1, 4	Check that the CPS documents all security measures and server and network configurations.			☐ Pass ☐ Fail ☐ Not applicable

2.2.3 Requirements for relying parties and subscribers of the CA

Control procedures referenced in this Section refer to Section 7.2.3 of (ISO27099). Concerning requirements for relying parties and subscribers of the CA, the following control procedures SHALL be fulfilled as requirements:

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
(1) from Section 7.2.3	1, 4	Check that requirement according to section 7.2.3 (1) of ISO 27099 is fulfilled.			☐ Pass ☐ Fail ☐ Not applicable
(2) from Section 7.2.3	1, 4	Check that requirement of to section 7.2.3 (2) of ISO 27099 is fulfilled.			☐ Pass ☐ Fail ☐ Not applicable
(6) from Section 7.2.3	1, 4	Check that the subscriber agreement specifies the requirements for notification of the CA concerning any event that affects the certificate validity.			☐ Pass ☐ Fail ☐ Not applicable

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
2.2.3A1	1, 4	Check that the CA makes each version of its Terms and Conditions available to its subscribers and relying parties.			☐ Pass ☐ Fail ☐ Not applicable
2.2.3A2	1, 4	Check that each version of the CA's Terms and Conditions is uniquely identifiable, e.g. by a unique version number contained in the text.			☐ Pass ☐ Fail ☐ Not applicable
2.2.3A3	1, 4	Check that the CA oblige the subscribers and advise the relying parties, e.g. within its CP or Terms and Conditions, to validate the CA certificate and the subscriber certificates.			☐ Pass ☐ Fail ☐ Not applicable
2.2.3A4	1, 4	Check that the dissemination of Terms and Conditions is protected from manipulation.			☐ Pass ☐ Fail ☐ Not applicable

2.3 Information security policy

Control procedures referenced in this Section refer to Section 7.3 of (ISO27099). Concerning the information security the following control procedures SHALL be fulfilled as requirements:

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
(1) from Section 7.3	1, 4	Check that an information security policy document fulfils all the requirements as defined in section 7.3 (1) of ISO 27099. The auditor must check each requirement listed in section 7.3 (1) of ISO 27099 separately, thus the enumeration (a), (b) of ISO 27099 is substituted by (i), (ii) of this TS.			☐ Pass ☐ Fail ☐ Not applicable

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
(3) from Section 7.3	1, 4	Check that the information security policy includes at least the points according to section 7.3 (3) of ISO 27099. Each of the bullet points must be checked by the auditor thus the enumeration of (a) to (f) of section 7.3. (3) is substituted by (i) to (vi) according to this TS.			☐ Pass ☐ Fail ☐ Not applicable
(4) from Section 7.3	1, 4	Check that requirement defined in section 7.3 (4) of ISO27099 is fulfilled.			☐ Pass ☐ Fail ☐ Not applicable
(5) from Section 7.3	1, 4	Check that the requirements as defined in section 7.3 (5) of ISO 27099 is fulfilled.			☐ Pass ☐ Fail ☐ Not applicable
(6) from Section 7.3	1, 4	Check that there exists a risk management system and all requirements according to section 7.3 (6) of ISO 27099 are fulfilled.			☐ Pass ☐ Fail ☐ Not applicable
(7) from Section 7.3	1, 4	Check that requirement 7.3 (7) of ISO 27099 is fulfilled.			☐ Pass ☐ Fail ☐ Not applicable
(12) from Section 7.3	1, 4	If the CA outsources the management and control of all or some of its information systems, networks or desktop environment check that all security requirements of section 7.3 (12) of ISO 27099 are met.			☐ Pass ☐ Fail ☐ Not applicable
(13) from Section 7.3	1, 4	If the CA chooses to delegate a portion of the CA roles and respective functions to another party, check that requirement in section 7.3 (13) of ISO 27099 is fulfilled.			☐ Pass ☐ Fail ☐ Not applicable
(14) from Section 7.3	1, 4	Check that processes operated by subcontractors are subject to applicable requirements from this document.			☐ Pass ☐ Fail ☐ Not applicable

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
(15) from Section 7.3	1, 4	Check that requirement 7.3 (15) of ISO 27099 is fulfilled.			☐ Pass ☐ Fail ☐ Not applicable
2.3A1	1, 4	Check that the CA implements and adheres to its information security policy.			☐ Pass ☐ Fail ☐ Not applicable

2.4 Asset classification and management

Control procedures referenced in this Section refer to Section 7.4 of (ISO27099). The following control procedures SHALL be fulfilled as requirements:

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
(1) from Section 7.4	1, 4	Check that for all CA assets owners are identified and responsibility for the maintenance of appropriate controls are assigned.			☐ Pass ☐ Fail ☐ Not applicable
(2) from Section 7.4	1, 4	Check the requirements of section 7.4 (2) of ISO 27099 are implemented.			☐ Pass ☐ Fail ☐ Not applicable
(3) from Section 7.4	1, 4	Check that the requirement from section 7.4 (3) of ISO 27099 is fulfilled.			☐ Pass ☐ Fail ☐ Not applicable
(4) from Section 7.4	1, 4	Check that the procedures according to section 7.4 (4) of ISO 27099 are defined.			☐ Pass ☐ Fail ☐ Not applicable

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
(5) from Section 7.4	1, 4	Check that procedures for the management of removable computer media are as defined in section 7.4. (5) of ISO 27099. The auditor must check each listed requirement of section 7.4 (5), thus the enumeration from (a) to (c) of ISO 27099 is substituted by enumeration (i) to (iii) as defined in this TS.			☐ Pass ☐ Fail ☐ Not applicable
(6) from Section 7.4	1, 4	Check that all requirements for storage devices as defined in section 7.4 (6) of ISO 27099 are fulfilled.			☐ Pass ☐ Fail ☐ Not applicable
(7) from Section 7.4	1, 4	If applicable, check that the CA implements procedures for the archiving of information on subscribers and their certificates sufficient for the certificate renewal, re-keying, and update processes.			☐ Pass ☐ Fail ☐ Not applicable

2.5 Human resources security

Control procedures referenced in this Section refer to Section 7.5 of (ISO27099). Concerning the trustworthiness of personnel, the following control procedures SHALL be fulfilled as requirements:

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
(1) from Section 7.5	1, 4	Check that it is ensured that the selected CA employs personnel having the necessary knowledge, experience and skills to carry out the work.			☐ Pass ☐ Fail ☐ Not applicable

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
(2) from Section 7.5	1, 4	Check that the security roles and responsibilities, as specified in the organization's security policy, are documented. Check that trusted roles, on which the security of the CA's operation is dependent, are clearly identified.			☐ Pass ☐ Fail ☐ Not applicable
(3) from Section 7.5	1, 4	Check that trusted roles at least include roles that involve the following responsibilities as defined in section 7.5 (3) from ISO 27099. The auditor must check each listed responsibility defined in section 7.5 (3), thus the enumeration of (a) to (h) of ISO 27099 is substituted by (i) to (viii) according to this TS.			☐ Pass ☐ Fail ☐ Not applicable
(4) from Section 7.5	1, 4	Check that all requirements in section 7.5 (4) as defined in ISO 27099 is fulfilled.			☐ Pass ☐ Fail ☐ Not applicable
(5) from Section 7.5	1, 4	Check that an individual's trusted status has been approved before granting access to systems/facilities or performing actions that require trusted status.			☐ Pass ☐ Fail ☐ Not applicable
(6) from Section 7.5	1, 4	Check that contractors who perform trusted roles undergo the same background checks and personal management procedures as employees.			☐ Pass ☐ Fail ☐ Not applicable
(8) from Section 7.5	1, 4	Check that a disciplinary process exists and be followed as defined in section 7.5 (8) of ISO 27099.			☐ Pass ☐ Fail ☐ Not applicable

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
(9) from Section 7.5	1, 4	Check that CA ensures to take appropriate timely action as defined in section 7.5 (9) of ISO 27099.			☐ Pass ☐ Fail ☐ Not applicable
(11) from Section 7.5	1, 4	Check that requirement 7.5 (11) of ISO 27099 is fulfilled.			☐ Pass ☐ Fail ☐ Not applicable
2.5A1	1, 4	Check that the responsibilities bound to the roles at the CA and RA, and the boundaries of each of these responsibilities are well-defined in order to enable a clear structure in staff organization at the CA and RA.			☐ Pass ☐ Fail ☐ Not applicable

2.6 Physical and environmental security

Control procedures referenced in this Section refer to Section 7.6 of (ISO27099). Concerning the physical and environmental security, the following control procedures SHALL be fulfilled as requirements:

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
(3) from Section 7.6	1, 4	Check that access to the building or site housing CA operations is restricted as defined in section 7.6 (3) of ISO 27099.			☐ Pass ☐ Fail ☐ Not applicable
(4) from Section 7.6	1, 4	Check that physical barriers are in place (e.g. solid walls that extend from real floor to real ceiling) are in place to prevent unauthorised access and environmental contamination to the CA's certificate manufacturing facility.			☐ Pass ☐ Fail ☐ Not applicable

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
(5) from Section 7.6	1, 4	Check that physical barriers and protection against radiant emission (e.g. Faraday cage) and the requirements as defined in section 7.6 (5) of ISO 27099 are in place.			☐ Pass ☐ Fail ☐ Not applicable
(8) from Section 7.6	1, 4	Check that access to CA operational facilities is secured according to section 7.6 (8) of ISO 27099.			☐ Pass ☐ Fail ☐ Not applicable
(10) from Section 7.6	1, 4	Check that all entrance and leavings of personal to CAs operational facilities is locked according to ISO 27099 section 7.6 (10).			☐ Pass ☐ Fail ☐ Not applicable
(11) from Section 7.6	1, 4	Check that visitors to CA facilities are supervised and records are taken as defined in section 7.6 (11) of ISO 27099.			☐ Pass ☐ Fail ☐ Not applicable
(12) from Section 7.6	1, 4	Check that, the restrictions on personal of third party support service are enforced as defined in section 7.6 (12) from ISO 27099.			☐ Pass ☐ Fail ☐ Not applicable
(13) from Section 7.6	1, 4	Check that access rights to CA facilities are regularly updated and reviewed.			☐ Pass ☐ Fail ☐ Not applicable
(14) from Section 7.6	1, 4	Check that elements of CA's systems which are identified as critical to the security of its operations are within a physically secure boundary that physically restricts access by unauthorised personnel.			☐ Pass ☐ Fail ☐ Not applicable
(17) from Section 7.6	1, 4	Check that the requirement (17) of section 7.6 from ISO 27099 is fulfilled.			☐ Pass ☐ Fail ☐ Not applicable

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
(20) from Section 7.6	1, 4	Check that all requirements of storage media as defined in section 7.6 (20) of ISO 27099 are implemented.			☐ Pass ☐ Fail ☐ Not applicable
(21) from Section 7.6	1, 4	Check that the CA implements the controls as defined in section 7.6 (21) of ISO 27099.			☐ Pass ☐ Fail ☐ Not applicable
(24) from Section 7.6	1, 4	Check that procedures as defined in section 7.6 (24) of ISO 27099 are place.			☐ Pass ☐ Fail ☐ Not applicable
(25) from Section 7.6	1, 4	Check that physical access to the secure cryptographic device is only possible under multiple controls, which are limited to authorised entities. .			☐ Pass ☐ Fail ☐ Not applicable
2.6A1	1, 4	Check that physical access to CA facilities is limited to authorized individuals. For virtualised environments, check that the CA software is isolated from other software and access is limited to authorized individuals.			☐ Pass ☐ Fail ☐ Not applicable
2.6A2	1, 4	Check that security levels are defined for the premises of the CA, CA facilities, supplying facilities and/or parts of them. Check that the access to the security levels is defined by an access list and is reviewed regularly. Check that the physical protection is ensured by clearly defined security perimeters for the defined security levels.			☐ Pass ☐ Fail ☐ Not applicable

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
2.6A3	1, 4	Check that all premises shared with external organizations are outside of the security perimeters.			☐ Pass ☐ Fail ☐ Not applicable
2.6A4	1, 4	Check that continuous power supply is ensured for all critical processes by an uninterruptible power supply (UPS) system.			☐ Pass ☐ Fail ☐ Not applicable

2.7 Operational security

Control procedures referenced in this Section refer to Section 7.7 of (ISO27099). The following control procedures SHALL be fulfilled as requirements:

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
(1) from Section 7.7	1, 4	Check that the CA operating procedures are documented and maintained for each functional area.			☐ Pass ☐ Fail ☐ Not applicable
(2) from Section 7.7	1, 4	Check that formal management responsibilities and procedures exist as defined in section 7.7 (2) according to ISO 27099.			☐ Pass ☐ Fail ☐ Not applicable
(3) from Section 7.7	1, 4	Check that the requirements according to section 7.7 (3) of ISO 27099 is fulfilled.			☐ Pass ☐ Fail ☐ Not applicable
(4) from Section 7.7	1, 4	Check that the requirements on development and testing facilities are as defined in section 7.7 (4) from ISO 27099.			☐ Pass ☐ Fail ☐ Not applicable

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
(5) from Section 7.7	1, 4	Check that capacity demands are monitored, and projections of future capacity requirements are made to ensure that adequate processing power and storage are available.			☐ Pass ☐ Fail ☐ Not applicable
(6) from Section 7.7	1, 4	Check that acceptance criteria for new information systems, upgrades and new versions are established and that suitable tests of the system carried out prior to acceptance.			☐ Pass ☐ Fail ☐ Not applicable
(7) from Section 7.7	1, 4	Check that detection and prevention controls against malware and viruses are implemented and check that appropriate awareness programmes are in place as defined in section 7.7 (7) of ISO 27099.			☐ Pass ☐ Fail ☐ Not applicable
(8) from Section 7.7	1, 4	Check that all requirements on incident reporting procedures and documentations are existing and implemented as defined in section 7.7 (8) from ISO 27099.			☐ Pass ☐ Fail ☐ Not applicable
(9) from Section 7.7	1, 4	Check that reactions by the CA are planned in case security relevant algorithms or processes are broken/insecure as defined in section 7.7 (9) of ISO 27099.			☐ Pass ☐ Fail ☐ Not applicable
(10) from Section 7.7	1, 4	Check that the CA ensures timely, appropriate reaction to incidents.			☐ Pass ☐ Fail ☐ Not applicable
(11) from Section 7.7	1, 4	Check that users of CA systems with trusted roles are required to note and report observed or suspected security weaknesses in, or threats to, systems or services to ensure an appropriate response to a security incident.			☐ Pass ☐ Fail ☐ Not applicable

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
(12) from Section 7.7	1, 4	Check that procedures exist and are followed as defined in section 7.7 (12) of ISO 27099.			☐ Pass ☐ Fail ☐ Not applicable
(13) from Section 7.7	1, 4	Check that procedures exist and are followed as defined in section 7.7 (13) according to ISO 27099.			☐ Pass ☐ Fail ☐ Not applicable
(14) from Section 7.7	1, 4	Check that a formal problem management process exists that fulfils the requirements as defined in section 7.7 (14) of ISO 27099.			☐ Pass ☐ Fail ☐ Not applicable
(15) from Section 7.7	1, 4	Check that the CA ensures that any security breach results in an appropriate countermeasure to limit the impact in a timely and coordinated manner.			☐ Pass ☐ Fail ☐ Not applicable
2.7A1	1	Check that an analysis of the estimated usage of the CA services is done before setting-up the technical infrastructure. Check that the performance of the technical infrastructure is sufficient for the requirements and scalable without interrupting the continuous operation.			☐ Pass ☐ Fail ☐ Not applicable
	4	Check that the CA provides a degree of availability of its services towards its subscribers tailored appropriate to the interval of certificate issuing.			☐ Pass ☐ Fail ☐ Not applicable
2.7A2	1, 4	Check that written procedures exist for all operational CA processes, including the information of the associated roles.			☐ Pass ☐ Fail ☐ Not applicable

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
2.7A3	1, 4	Check that persons who are involved in the registration process of applicants are not involved in the certificate generation process or vice versa.			☐ Pass ☐ Fail ☐ Not applicable
2.7A4	1, 4	Check that the CA employs sufficient personnel for all critical services.			☐ Pass ☐ Fail ☐ Not applicable
2.7A5	1, 4	Check that penetration testing is conducted regularly, in a period of [assignment: number of days, weeks or months].			☐ Pass ☐ Fail ☐ Not applicable
2.7A6	1	Check that the CA defines the maximal tolerable downtime of each service. Check that the CA tailors the services appropriately.			☐ Pass ☐ Fail ☐ Not applicable
	4	Check that the CA defines the maximal tolerable downtime of each service. Check that the CA tailors the services appropriately. Particularly check that the service treating the suspension of certificates shall ensure to process inquiries and updates within [assignment: number of hours] hours.			☐ Pass ☐ Fail ☐ Not applicable

2.8 Access control

Control procedures referenced in this Section refer to Section 7.8 of (ISO27099).

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
(1) from Section 7.8	1, 4	Check that the access control requirements are defined and documented in an access control policy which should include at least the criteria defined in section 7.8 (1) of ISO 27099. The auditor shall check each requirement, thus the enumeration (a) to (d) from section 7.8 (1) is substituted by (i) to (iv) of this TS.			☐ Pass ☐ Fail ☐ Not applicable
(2) from Section 7.8	1, 4	Check that there is a formal, trusted procedure for registering and deregistering users of the CA's information systems and services.			☐ Pass ☐ Fail ☐ Not applicable
(3) from Section 7.8	1, 4	Check that section 7.8 (3) of ISO 27099 is followed.			☐ Pass ☐ Fail ☐ Not applicable
(5) from Section 7.8	1, 4	Check that reviewing of access right for user with trusted roles is done as defined in section 7.8 (5) from ISO 27099.			☐ Pass ☐ Fail ☐ Not applicable
(10) from Section 7.8	1, 4	Check that controls for network protection for the internal CA's network domain is in place in accordance with ISO 27099 section 7.8 (10).			☐ Pass ☐ Fail ☐ Not applicable
(11) from Section 7.8	1, 4	Check that all requirements as defined in section 7.8 (11) of ISO 27099 are fulfilled.			☐ Pass ☐ Fail ☐ Not applicable
(13) from Section 7.8	1, 4	Check that all local network components are kept inside a secure area and their configurations are regularly audited for conformance, as specified in section 7.8. (13) of ISO 27099.			☐ Pass ☐ Fail ☐ Not applicable

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
(15) from Section 7.8	1, 4	Check that the CA monitors access to its system to detect unauthorized access as defined in section 7.8 (15) of ISO 27099.			☐ Pass ☐ Fail ☐ Not applicable
(16) from Section 7.8	1, 4	Check that all requirements according to section 7.8 (16) of ISO 27099 are fulfilled.			☐ Pass ☐ Fail ☐ Not applicable
(17) from Section 7.8	1, 4	Check that the CA's operating systems are configured as defined in section 7.8 (17) of ISO 27099.			☐ Pass ☐ Fail ☐ Not applicable
(18) from Section 7.8	1, 4	Check that operating system patches and updates are applied as defined in section 7.8 (18) of ISO 27099.			☐ Pass ☐ Fail ☐ Not applicable
(19) from Section 7.8	1, 4	Check that access to CA systems requires a protected log-on process.			☐ Pass ☐ Fail ☐ Not applicable
(20) from Section 7.8	1, 4	Check that all requirements according to section 7.8 (20) of ISO 27099 are fulfilled.			☐ Pass ☐ Fail ☐ Not applicable
(21) from Section 7.8	1, 4	Check that uses of system utility programmes are restricted to authorized personnel and are tightly controlled as defined in section 7.8 (21) of ISO 27099.			☐ Pass ☐ Fail ☐ Not applicable
(23) from Section 7.8	1, 4	Check that the CA servers used for certificate manufacturer is configured as defined in section 7.8 (23) of ISO 27099. Check that this covers configuration and settings as defined in ISO 27099, section 7.8 (23).			☐ Pass ☐ Fail ☐ Not applicable

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
(25) from Section 7.8	1, 4	Before using critical applications, check that CA personal is successfully identified and authenticated according section 7.8 (25) of ISO 27099.			☐ Pass ☐ Fail ☐ Not applicable
(26) from Section 7.8	1, 4	Check that requirement for sensitive systems (e.g. root CA) according to section 7.8 (26) as defined in ISO 27099 is fulfilled.			☐ Pass ☐ Fail ☐ Not applicable
2.8A1	1, 4	Check that staff employed by the CA does not have access to any service for which they are not explicitly authorized to use.			☐ Pass ☐ Fail ☐ Not applicable

2.9 System acquisition, development and maintenance

Control procedures referenced in this Section refer to Section 7.9 of (ISO27099). The following control procedures SHALL be fulfilled as requirements:

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
(2) from Section 7.9	1, 4	Check that software testing and change control procedures exist and are followed as defined in section 7.9 (2) of ISO 27099.			☐ Pass ☐ Fail ☐ Not applicable
(3) from Section 7.9	1, 4	Check that change control procedures are in place and followed for the hardware, network component and system configuration changes.			☐ Pass ☐ Fail ☐ Not applicable
(5) from Section 7.9	1, 4	Check that, after operating system changes have occurred, that they are reviewed and tested.			☐ Pass ☐ Fail ☐ Not applicable

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
2.9A1	1, 4	Check that Test PKI operations are operated strictly separated from productive PKI operations.			☐ Pass ☐ Fail ☐ Not applicable
2.9A2	1, 4	Check that a productive CA does not issue test certificates.			☐ Pass ☐ Fail ☐ Not applicable

2.10 Business continuity management

Control procedures referenced in this Section refer to Section 7.10 of (ISO27099). Concerning business continuity management the following control procedures SHALL be fulfilled as requirements:

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
(1) from Section 7.10	1, 4	Check that all requirements from section 7.10 (1) of ISO 27099 are followed.			☐ Pass ☐ Fail ☐ Not applicable
(2) from Section 7.10	1, 4	Check that the CA has a business continuity plan to maintain or restore the CA's operations in a timely manner following interruption to, or failure of, critical CA processes that shall include all the points outlined in section 7.10 (2) from ISO 27099. The auditor shall check each requirement listed in section 7.10 (2) of ISO 27099, thus the enumeration (a) to (j) from section 7.10 (2) is substituted by (i) to (x) of this TS.			☐ Pass ☐ Fail ☐ Not applicable
(3) from Section 7.10	1, 4	Check that the CA's business continuity plans cover all critical components (i.e. hardware, software and keys) and include measures for recovering from the compromise or loss of CA private keys. These measures			☐ Pass ☐ Fail ☐ Not applicable

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
		a), b) as defined in section 7.10.(3) of ISO 27099 may be applied.			
(4) from Section 7.10	1, 4	Check that all requirements for backup copies of essential business information according to section 7.10 (4) of ISO 27099 applies.			☐ Pass ☐ Fail ☐ Not applicable
(6) from Section 7.10	1, 4	Check that the CA's business continuity plans include procedures for securing its facility to the fullest extent possible during the period of time following a disaster and prior to restoring a secure environment either at the original site or a remote site.			☐ Pass ☐ Fail ☐ Not applicable
(9) from Section 7.10	1, 4	Check the effectiveness of business continuity plans by carrying out regular reviews and updates in accordance with section 7.10. (9) of ISO 27099.			☐ Pass ☐ Fail ☐ Not applicable
2.10A1	1, 4	Check that the CA ensures that after an incident the security vulnerability, which caused the incident, is fixed or sufficiently mitigated. Check that afterwards a timely restart of the services is processed.			☐ Pass ☐ Fail ☐ Not applicable
2.10A2	1, 4	Check that for each defined role there is at least one substitute to limit negative effects on the process-flow conducted at the CA if an individual is unavailable to fulfil his or her role.			☐ Pass ☐ Fail ☐ Not applicable
2.10A3	1, 4	Check that data regarding CA operation is backed-up. Check that this backup ensures the operation of the CA in case of an emergency.			☐ Pass ☐ Fail ☐ Not applicable

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
		Check that at least the backups of critical data are realized physically separated from regular operations.			

2.11 Monitoring, conformance and compliance

Control procedures referenced in this Section refer to Section 7.11 of (ISO27099). The following control procedures SHALL be fulfilled as requirements:

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
(4) from Section 7.11	1, 4	Check those records that are relevant for monitoring and conformance are protected from loss, destruction, and falsification.			☐ Pass ☐ Fail ☐ Not applicable
(6) from Section 7.11	1, 4	Check that the CA's operations is subject to regular review to ensure it is in accordance with its CPS.			☐ Pass ☐ Fail ☐ Not applicable
(8) from Section 7.11	1, 4	Check that procedures for CA system usage have been established as defined in section 7.11 (8) of ISO 27099. Check that alerting mechanisms are implemented to detect both unauthorized access and unauthorized modification attempts.			☐ Pass ☐ Fail ☐ Not applicable

2.12 Audit journal security and archiving

Control procedures referenced in this Section refer to Section 7.12 of (ISO27099). Concerning the archiving and tracking of relevant events, the following control procedures SHALL be fulfilled as requirements:

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
(1) from Section 7.12	1, 4	Check that the CA generates automatic (electronic) and manual audit logs as stated and required by the certificate policy.			☐ Pass ☐ Fail ☐ Not applicable
(2) from Section 7.12	1, 4	Check that all journey entries must include date and time of the entry and check that all elements as mentioned in section 7.12 (2) from ISO 27099 are included in the journey, if relevant. The auditor must check all listed requirements of section 7.12 (2) separately, thus the enumeration from (a) to (c) of ISO 27099 is substituted by (i) to (iii) according to this TS.			☐ Pass ☐ Fail ☐ Not applicable
(3) from Section 7.12	1, 4	Check that all the archived audit logs are secured as defined in section 7.12 (3) of ISO 27099.			☐ Pass ☐ Fail ☐ Not applicable
(4) from Section 7.12	1, 4	Check that the CA implements an audit trail with the purpose to identify evidence of any malicious activities. Check that the roles and responsibilities for regularly monitoring and reviewing these audit logs are clearly defined.			☐ Pass ☐ Fail ☐ Not applicable
(8) from Section 7.12	1	Check that the CA logs (or require that the RA records) the certificate application information. Check that this includes all the points as defined in section 7.12 (8) of ISO 27099. The auditor shall check each points of section 7.12. (8) separately , thus the enumeration (a) – (h) is substituted by (i) to (viii) according to this TS.			☐ Pass ☐ Fail ☐ Not applicable
	4	Check that the CA logs (or require that the RA records) the certificate application information.			☐ Pass ☐ Fail ☐ Not applicable

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
		Check that this includes: (i) the method of identification applied, and information used to meet “know-your-customer” requirements; (ii) identification and registration data as defined in the corresponding CP; (iii) identity of entity accepting the application as defined in the corresponding CP; (iv) validation of identification documents as defined in the corresponding CP; (v) name of receiving CA or submitting RA; (vi) the subject’s acceptance of the subscriber agreement; (vii) the subscriber’s consent to allow the CA to keep records containing personal data and pass this information to specified third parties, and publication of certificates.			
(9) from Section 7.12	1	Check that the CA logs all certificate life cycle management related events as defined in section 7.12 (9) from ISO 27099. The auditor shall check each certificate life cycle event as listed in section 7.12. (9) from ISO 27099 separately, thus the enumeration of (a) to (j) of ISO 27099 is substituted by (i) to (x) as defined in the TS.			☐ Pass ☐ Fail ☐ Not applicable
	4	Check that the CA logs certificate life cycle management related events according to section 7.12. (9) of ISO 27099. Check that this includes: (i) certificate requests;			☐ Pass ☐ Fail ☐ Not applicable

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
		(ii) rekey requests; (iii) submissions of public keys for certification; (iv) change of registration information of an entity; (v) generation and distribution of certificates; (vi) distribution of the CA's public key; (vii) requests for certificate revocation or suspension; (viii) revocation of a certificate that has been issued by the CA; (ix) certificate suspension requests (if supported); (x) certificate suspension and reactivation (if supported); (xi) generation and issuance of certificate revocation lists (if supported).			
(11) from Section 7.12	1, 4	Check that audit logs do not record the private keys in any form (e.g. plaintext or enciphered).			☐ Pass ☐ Fail ☐ Not applicable
(12) from Section 7.12	1, 4	Check that CA computer system clock requirement as defined in 7.12 (12) of ISO 27099 is fulfilled.			☐ Pass ☐ Fail ☐ Not applicable
(14) from Section 7.12	1, 4	Check that the length of time for audit log retention is follows section 7.12 (14) from ISO 27099.			☐ Pass ☐ Fail ☐ Not applicable
(15) from Section 7.12	1, 4	Check that the CA retains audit log data for the specified period as defined in section 7.12 (15) of ISO 27099.			☐ Pass ☐ Fail ☐ Not applicable

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
(18) from Section 7.12	1, 4	Check that audit logs are reviewed in accordance with the practices established in the CPS.			☐ Pass ☐ Fail ☐ Not applicable
(19) from Section 7.12	1, 4	Check that the review of current and archived audit logs is done as defined in section 7.12 (19) of ISO 27099 and check that all requirements mentioned in this section applies.			☐ Pass ☐ Fail ☐ Not applicable
2.12A1	1	Check that the CA logs CA key life cycle management related events. Check that this includes: • CA key generation; • manual installation of cryptographic keys (if supported); • CA key back-up (if supported); • CA key storage; • CA key recovery (if supported); • CA key escrow activities (if supported); • CA key usage; • CA key archival (if supported); • CA key revocation (if supported); • CA key destruction; • identity of the entity authorizing a key management operation;			☐ Pass ☐ Fail ☐ Not applicable

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
		- identity of the entities handling any keying material (such as key components or keys stored in portable devices or media); - custody of keys and of devices or media holding keys.			
2.12A2	1, 4	Check that audit trail data is append-only.			☐ Pass ☐ Fail ☐ Not applicable
2.12A3	1, 4	Check that the CA ensures that a complete set of information concerning a certificate is archived. Check that this set of information is - clearly and a priori defined, - stored for an a priori defined, appropriate time, and - unambiguously be referred to a certificate.			☐ Pass ☐ Fail ☐ Not applicable
2.12A4	1	Check that the set of information to be archived and the period of time for keeping the archived information is defined in the CA's Terms and Conditions. Check that for each event to be archived, the event time is recorded precisely.			☐ Pass ☐ Fail ☐ Not applicable
	4	Check that the set of information to be archived and the period of time for keeping the archived information is defined in the CA's CP. Check that for each event to be archived, the event time is recorded precisely.			☐ Pass ☐ Fail ☐ Not applicable

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
2.12A5	1, 4	Check that the archived set of information, the mapping onto certificates and to the registered subscribers is sufficient for all applicable processes of certificate renewal, re-keying and update.			☐ Pass ☐ Fail ☐ Not applicable

2.13 Controlled CA termination

Control procedures referenced in this Section refer to Section 7.15.9 of (ISO27099). Concerning the cessation of operation of a CA, the following control procedures SHALL be fulfilled as requirements:

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
(1) from Section 7.15.9	1, 4	Check that a termination plan has been established which includes all points from ISO 27099, 7.15.9. (1).			☐ Pass ☐ Fail ☐ Not applicable
(5) from Section 7.15.9	1, 4	Check that a termination plan has been developed to minimise disruption. This should include notification to subscribers, preserving records, transferring business to a reliable successor.			☐ Pass ☐ Fail ☐ Not applicable
(7) from Section 7.15.9	1	Check that the CA makes certificate status information (including certificate revocation lists and other certificate status mechanisms) available to relevant entities (e.g. subscribers and relying parties or their agents, i.e. CVSPs) using mechanism in accordance with the CP.			☐ Pass ☐ Fail ☐ Not applicable
	4	Not applicable to CAs affected by (BSI-TR-03145-4)			☐ Pass ☐ Fail ☒ Not applicable

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
(8) from Section 7.15.9	1, 4	Check that the CA has a plan for the case of business termination, that at least includes the points as defined in section 7.15.9 (8) from ISO 27099. The auditor shall check each separately, thus the enumeration of 7.15.9 (8) (a) to (e) is substituted by (i) to (v) as defined by this TS.			☐ Pass ☐ Fail ☐ Not applicable
(9) from Section 7.15.9	1	Check that the CA ensures to inform all stakeholders prior to its business termination.			☐ Pass ☐ Fail ☐ Not applicable
	4	Check that sub-CA informs subscribers, subjects and the root-CA as well as other entities the sub-CA has agreements with about successor instances (i.e. third party service providers) prior to its termination. Check that the process of the CA termination is described in the CA's Terms and Conditions.			☐ Pass ☐ Fail ☐ Not applicable
	4	Check that the CA ensures that if a subscriber of a CA declares the termination of its business within the PKI, the subscriber is suspended by its CA at the termination date.			☐ Pass ☐ Fail ☐ Not applicable
	4	Check that the CA ensures that if a subscriber of a CA declares the termination of its business within the PKI, the last certificate which will be issued for that subscriber does not have the end of validity beyond the termination date.			☐ Pass ☐ Fail ☐ Not applicable
2.13A1	1, 4	If no successor instance for a transition period is defined and guaranteed for the case of CA termination, check that the CA has a guaranteed plan for an alternative secure termination of all services.			☐ Pass ☐ Fail ☐ Not applicable

3 Key life cycle management

3.1 CA key life cycle management

The private key of a CA forms the basis for the CA's trustworthiness. Therefore, the CA shall ensure that its own CA key pair, in particular its own private key, is maintained securely during the whole key life cycle.

Please mark, if the CA uses separate key pairs with corresponding certificates to sign certificates, revocation lists and to issue OCSP signers

☐ No

☐ Yes

If Yes, please mark for what the separate key pairs and corresponding certificates are used by the CA (multiple selection possible)

☐ signing certificates

☐ signing CRLs

☐ issuing OCSP signers

☐ others: _____

If more than one single CA is in the scope of the audit this may have to be specified for each individual CA.

Note that the requirements from this Section apply to all of the CA's own key pairs.

Concerning the management of the CA's keys during the whole key lifecycle the following requirements SHALL be fulfilled:

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
3.1A1	1	Check that private keys of the CA are generated and handled in a certified security device compliant with [assignment: Security Level 2 according to (KLSR), (ISO15408), equivalent, appropriate application specific requirements] ensuring the claimed security features, including tamper resistance, mitigation of side			☐ Pass ☐ Fail ☐ Not applicable

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
		channels, suitable access control, random number generator and security of cryptographic operations. Check that appropriate access control ensures that the keys are not accessible from outside.			
	4	Check that private keys of the CA are generated, held, used and deleted in a security device following the requirements of the Certificate Policy of the Root-CA ensuring the claimed security features, including tamper resistance, mitigation of side channels, suitable access control, random number generator and security of cryptographic operations.			☐ Pass ☐ Fail ☐ Not applicable
3.1A2	1, 4	Check that private keys of the CA are handled (e.g. generated, stored, used or recovered) only by personnel in trusted roles.			☐ Pass ☐ Fail ☐ Not applicable

3.1.1 CA key generation

Control procedures referenced in this Section refer to Section 7.13.1 of (ISO27099). Concerning the generation of the CA's own key pair, the following control procedures SHALL be fulfilled as requirements:

Requirement		Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
(3) from Section 7.13.1	1	Check that the requirements for CA keys generation is done as defined in section 7.13.1 (3) of ISO 27099.			☐ Pass ☐ Fail ☐ Not applicable
	4	Check that the CA key pair generation is performed by trustworthy personnel during a key ceremony in a four-eyes principle under the attendance of the key			☐ Pass ☐ Fail ☐ Not applicable

Requirement		Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
		responsible officer in a physically secured environment.			
(4) from Section 7.13.1	1, 4	Check that generation requirements of its own key pair by the CA are implemented and followed as defined in section 7.13.1 (4).			☐ Pass ☐ Fail ☐ Not applicable
(5) from Section 7.13.1	1	Check that the CA generates keys as defined in section 7.13.1 (5) of ISO 27099. The auditor shall check each listed requirement of section 7.13.1 (5) of ISO 27099 separately, thus the enumeration (a) to (d) of ISO 27099 is substituted by (i) to (iv) according to this TS.			☐ Pass ☐ Fail ☐ Not applicable
	4	Not applicable to CAs affected by (BSI-TR-03145-4)			☐ Pass ☐ Fail ☒ Not applicable
(7) from Section 7.13.1	1, 4	Check that the operation of the user software and cryptographic hardware is tested before going into production.			☐ Pass ☐ Fail ☐ Not applicable
(10) from Section 7.13.1	1, 4	Check that the cryptographic hardware used by the CA is stored and used in a secure location that is only accessible to authorised personnel.			☐ Pass ☐ Fail ☐ Not applicable
(12) from Section 7.13.1	1, 4	Check that the CA's cryptographic hardware installation, removal, servicing, repair is carried out by at least two authorized personnel.			☐ Pass ☐ Fail ☐ Not applicable
3.1.1A1	1	Check that the generation of a new key pair and the corresponding CA certificate is done at least [assignment: number of days more than 2] days before the private key usage period of the previous CA certificate ends.			☐ Pass ☐ Fail ☐ Not applicable

Requirement		Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
	4	Check that the generation of a new key pair and the corresponding CA certificate is done according to the deadlines defined in the corresponding CP.			☐ Pass ☐ Fail ☐ Not applicable

3.1.2 CA key storage, backup, and recovery

Control procedures referenced in this Section refer to Section 7.13.2 of (ISO27099). Concerning the storage, backup and recovery of the CA's own key, the following control procedures SHALL be fulfilled as requirements:

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
(2) from Section 7.13.2	1, 4	If the CA's private keys are export all the requirements as defined in section 7.13.2 (2) of ISO 27099 must be applied. The auditor must check all listed requirements of section 7.13.2 (2) separately, thus the enumeration from (a) to (c) of ISO 27099 is substituted by (i) to (iii) according to this TS.			☐ Pass ☐ Fail ☐ Not applicable
(5) from Section 7.13.2	1, 4	Check that the recovery of the CA's keys is carried out in a manner that is as secure as the backup process.			☐ Pass ☐ Fail ☐ Not applicable
(7) from Section 7.13.2	1, 4	Check that the CA's cryptographic hardware is stored and used in a secure site, with access limited to authorized personnel. Check that all requirements of section 7.13.2 (7) are fulfilled. The auditor must check all listed requirements of section 7.13.2 (7) separately, thus the enumeration from (a) to (e) of ISO 27099 is substituted by (i) to (v) according to this TS.			☐ Pass ☐ Fail ☐ Not applicable

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
(8) from Section 7.13.2	1, 4	Check that the handling of CA cryptographic hardware is performed as defined in section 7.13.2 (8) of ISO 27099.			☐ Pass ☐ Fail ☐ Not applicable
3.1.2A1	1	Check that backups of the CA keys are made			☐ Pass ☐ Fail ☐ Not applicable
	4	Check that the root-CA makes backups of its keys. Check that the requirements defined in (KLSR) for the corresponding security level are fulfilled by the CA for the backups of its keys (this includes sub-CAs, if backups are supported by this sub-CA).			☐ Pass ☐ Fail ☐ Not applicable
3.1.2A2	1, 4	If private keys of the CA are stored outside the security device (e.g. as backup), check that the private keys are processed with the same level of protection as defined by requirement 3.1A1.			☐ Pass ☐ Fail ☐ Not applicable
3.1.2A3	1, 4	Check that any storage media containing backups of private keys is encrypted and secured against non-authorized usage. Check that the storage media is located in a physically and logically highly secured area. Check that access to this area is restricted to an appropriate set of persons which is clearly defined by their roles. Check that the number of authorized persons is restricted, while ensuring staff availability to carry out these tasks.			☐ Pass ☐ Fail ☐ Not applicable

3.1.3 CA public key distribution

Control procedures referenced in this Section refer to Section 7.13.3 of (ISO27099). Concerning the distribution of the CA's own public key, the following control procedures SHALL be fulfilled as requirements:

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
(1) from Section 7.13.3	1, 4	Check that provides a mechanism for validating the authenticity and integrity of its public key as defined in section 7.13.3 (1). Check that for subsequent and subordinate CA public keys are validated according to section 7.13.3 (1). If applicable, check that the CA issues a link certificate for its new public key before the expiration of its current public key.			☐ Pass ☐ Fail ☐ Not applicable
(5) from Section 7.13.3	1, 4	Check that any new CA public key is made available to relying parties.			☐ Pass ☐ Fail ☐ Not applicable
3.1.3A1	1, 4	Check that the public key fingerprint of a CA certificate is disseminated to the relying parties on a different channel than the corresponding CA certificate.			☐ Pass ☐ Fail ☐ Not applicable

3.1.4 CA key usage

Control procedures referenced in this Section refer to Section 7.13.4 of (ISO27099). Concerning the usage of the CA's own key, the following control procedures SHALL be fulfilled as requirements:

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
(1) from Section 7.13.4	1, 4	Check that the activation of the CA private signing key is performed as defined in section 7.13.4 (1) from ISO 27099.			☐ Pass ☐ Fail ☐ Not applicable
(2) from Section 7.13.4	1	Check that the activation of the CA private key is performed using multifactor authentication (e.g. smart card and password, biometric and password).			☐ Pass ☐ Fail ☐ Not applicable
	4	Check that the activation of the CA private key is performed using multifactor authentication using hardware tokens (e.g. smart card and password or PIN).			☐ Pass ☐ Fail ☐ Not applicable
(3) from Section 7.13.4	1, 4	Check that the CA signing key(s) used to generate certificates or issue revocation status information, are not used for any other purpose.			☐ Pass ☐ Fail ☐ Not applicable
(5) from Section 7.13.4	1, 4	Check that the CA ceases to use a key pair at the end of its defined operational lifetime, or when the private key has been compromised or is suspected to have been compromised.			☐ Pass ☐ Fail ☐ Not applicable
3.1.4A1	1, 4	Check that the private key is only set active for the period necessary. Check that the private key is deactivated if one of following cases occurs: - the key is intended not to be used until a fixed date, e.g. for disseminating the new certificate before it will be used; - the key is no longer in use because a new private key has been activated; - it is obvious that the key will not be used for a period of [assignment: number of days, weeks or months] due to a special use case.			☐ Pass ☐ Fail ☐ Not applicable

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
3.1.4A2	1	Check that for the activation of the key material, hardware tokens (e.g. smart cards) are used.			☐ Pass ☐ Fail ☐ Not applicable
	4	Not applicable to CAs affected by (BSI-TR-03145-4)			☐ Pass ☐ Fail ☒ Not applicable

3.1.5 CA key archival and destruction

Control procedures referenced in this Section refer to Section 7.13.5 of (ISO27099). Concerning the archival and destruction of the CA's own key, the following control procedures SHALL be fulfilled as requirements:

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
(1) from Section 7.13.5	1, 4	Where CA private keys are archived, check that the requirement of section 7.15.3 (1) of ISO 27099 is fulfilled.			☐ Pass ☐ Fail ☐ Not applicable
(3) from Section 7.13.5	1, 4	Check that authorisation to destroy a CA's private key, and the method of destruction (e.g. hardware token surrender, hardware token destruction or key overwrite) is limited in accordance with the CA's CPS.			☐ Pass ☐ Fail ☐ Not applicable
(4) from Section 7.13.5	1, 4	Check that all copies and fragments of the CA's private key are destroyed so that the private key cannot be recovered as defined in section 7.13.5 (4) of ISO 27099.			☐ Pass ☐ Fail ☐ Not applicable
(5) from Section 7.13.5	1, 4	Check that in case a CA cryptographic device is being permanently removed from service, all keys that have been used for cryptographic purpose shall be erased			☐ Pass ☐ Fail ☐ Not applicable

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
		from the device in use as defined in section 7.13.5 (5) of ISO 27099.			
(6) from Section 7.13.5	1, 4	Check that the CAs private key and all backups are destroyed in the way as described in section 7.13.5 (6) of ISO 27099.			☐ Pass ☐ Fail ☐ Not applicable
(7) from Section 7.13.5	1, 4	Check that the destruction of CA keys follows the requirements as described in section 7.13.5 (7) of ISO 27099.			☐ Pass ☐ Fail ☐ Not applicable
(9) from Section 7.13.5	1, 4	Check that algorithms and key length for key encryption of keys held outside HSM meets the requirements of section 7.13.5 (9) of ISO 27099.			☐ Pass ☐ Fail ☐ Not applicable
3.1.5A1	1, 4	Check that archived public keys are only used when historical evidence requires validation.			☐ Pass ☐ Fail ☐ Not applicable

3.1.6 CA key compromise

Control procedures referenced in this Section refer to 7.13.6 of (ISO27099). Concerning the compromise of the CA's own key, the following control procedures SHALL be fulfilled as requirements:

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
(1) from Section 7.13.6	1, 4	Check that the CA's business continuity plans describe the compromise or suspected compromise of a CA's private keys as a disaster.			☐ Pass ☐ Fail ☐ Not applicable
(2) from Section 7.13.6	1, 4	Check that disaster recovery procedures as defined in section 7.13.6 (2) of ISO 27099 exists.			☐ Pass ☐ Fail ☐ Not applicable

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
		Check that details of recovery as defined in section 7.13.6 (2) of ISO 27099 are part of the recovery plan.			

3.2 Subject key life cycle management

This section specifies requirements concerning the life cycle of subject keys and refers to Section 7.14 of (ISO27099). Concerning the secure handling of subject keys throughout the whole subject key life cycle, the following requirements apply:

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
3.2A1	1, 4	Check that the requirements on hard- and/or software to be used for handling (e.g. key generation or storage) of subject keys are specified by the CA in its Terms and Conditions.			☐ Pass ☐ Fail ☐ Not applicable
3.2A2	1, 4	Check that the CA defines in its Terms and Conditions the subscriber (and where applicable subject) obligations concerning the subscribers' (and where applicable subjects') operational environment in order to prevent unauthorized access to or alteration of subject keys.			☐ Pass ☐ Fail ☐ Not applicable
3.2A3	1, 4	Check that the CA defines in its Terms and Conditions subscriber (and where applicable subject) obligations concerning the subscriber's (and where applicable subject's) processes and operation environment for all subject key operations			☐ Pass ☐ Fail ☐ Not applicable
3.2A4	1, 4	Check that the CA specifies in its CP requirements and limitations for the usage of subject keys.			☐ Pass ☐ Fail ☐ Not applicable

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
		Check that all certificates issued by this CA contain information on the subject key usage correspondingly (cf. KeyUsage according to (RFC5280)). Check that the CA defines in its Terms and Conditions the obligations for subscribers (and where applicable of subjects) concerning the usage of subject keys.			
3.2A5	1, 4	Check that subject private keys are handled (e.g. generated, stored, used or recovered) only by trusted individuals			☐ Pass ☐ Fail ☐ Not applicable

3.2.1 Subject key generation and distribution

There are two alternative ways how the subject key pair can be generated and provided:

- The subject key pair is generated at the subject's or subscriber's premise and the public key is provided by the subject or subscriber during the identification and registration process to the issuing CA. This alternative is addressed in subsection 3.2.1.1.
- The CA generates a key pair on behalf of the subject, issues the corresponding certificate and delivers it to the subject or subscriber in a secure manner. Requirements for this alternative are described in subsection 3.2.1.2.

Despite of which alternative is chosen for subject key generation and distribution, the following requirement applies:

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
3.2.1A1	1, 4	Check that the CA implements mechanisms to correctly assign the subject's public key to the registration data.			☐ Pass ☐ Fail ☐ Not applicable

3.2.1.1 Subject keys provided by subscriber (if supported)

Please mark, if subject key generation by the subscriber is supported by the CA:

☐ Yes

☐ No

If subject key generation by the subscriber is supported by the CA, the following requirements concerning the subject key generation apply:

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
3.2.1.1A1	1, 4	Check that the CA determines the security level of the supported subscriber applications by considering a risk analysis of the business case and if applicable of legal requirements. Check that for subscriber applications with security level 'high', as e.g. Sub-CAs or qualified electronic signatures, the CA demands the usage of cryptographic modules (HSM or token) for the handling of subject keys, in particular for key generation and key storage,. Check that for subscriber applications with lower security level, the CA at least demands from subscribers to adopt the following security measures: use of virus protection, use of software firewall, installation of operating system security updates when they occur, [assignment: additional security measures]			☐ Pass ☐ Fail ☐ Not applicable
3.2.1.1A2	1	Check that the registration data is clearly defined by the CA and contains the public key of the subject and all subject attributes that are necessary for the registration process. Check that at least the public key and the subject attributes are signed with the subject's private key to			☐ Pass ☐ Fail ☐ Not applicable

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
		avoid alteration and to provide proof of possession of the private key. Check that the CA verifies this signature.			
	4	Check that the registration data is clearly defined by the CA and contains the public key of the subject and all subject attributes that are necessary for the registration process. Check that certificate requests comply with the corresponding CP.			☐ Pass ☐ Fail ☐ Not applicable
3.2.1.1A3	1, 4	Check that the CA validates if the subject key pair fulfils the cryptographic requirements. Check that the CA refuses the certificate request and does not generate a corresponding certificate if these requirements are not fulfilled.			☐ Pass ☐ Fail ☐ Not applicable

3.2.1.2 Subject keys provided by the CA (if supported)

Control procedures referenced in this Section refer to Section 7.14.1 of (ISO27099).

Please mark, if subject key generation by the CA on behalf of the subject is supported by the CA:

- ☐ Yes
☐ No

Note that (BSI-TR-03145-4) does not allow that the subject key is generated by the CA and disseminated to the subscriber.

If subject key generation by the CA on behalf of the subject is supported the following control procedures SHALL be fulfilled as requirements:

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
(2) from Section 7.14.1	1	Check that subject key generation follows the requirements as defined in section 7.14.1 (2) of ISO 27099.			☐ Pass ☐ Fail ☐ Not applicable
(3) from Section 7.14.1	1	Check that subject key generation performed by the CA fulfils the requirement as defined in section 7.14.1 (3) of ISO 27099.			☐ Pass ☐ Fail ☐ Not applicable
(4) from Section 7.14.1	1	Check that requirement 7.14.1 (4) from ISO 27099 is fulfilled.			☐ Pass ☐ Fail ☐ Not applicable
(5) from Section 7.14.1	1	Check that the CA's subject key generation process fulfils the requirements as defined in section 7.14.1 (5) of ISO 27099.			☐ Pass ☐ Fail ☐ Not applicable
(6) from Section 7.14.1	1	Check that the securely key delivery of subject key pair(s) by the CA is done and all requirements as defined in section 7.14.1 (6) from ISO 27099 are fulfilled. Check that the key pair is disseminated only to the subject.			☐ Pass ☐ Fail ☐ Not applicable
3.2.1.2A1	1	Check that the CA describes the key dissemination procedure in its Terms and Conditions.			☐ Pass ☐ Fail ☐ Not applicable
3.2.1.2A2	1	Check that the CA determines the security level of the supported subscriber applications by considering a risk analysis of the business case and if applicable of legal requirements. Check that for subscriber applications with security level 'high', as e.g. Sub-CAs or qualified electronic signatures, the CA demands the usage of a certified security device compliant with [assignment: Security			☐ Pass ☐ Fail ☐ Not applicable

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
		Level 2 according to (KLSR), (ISO15408), equivalent, appropriate application specific requirements] for the handling of subject keys, in particular for key generation and key storage. Check that an appropriate access control ensures that the keys are not accessible from outside. Check that for subscriber applications with lower security level, the CA at least demands from subscribers to adopt the following security measures: use of virus protection, use of software firewall, installation of operating system security updates when they occur, [assignment: additional security measures].			
3.2.1.2A3	1	Check if the private key has been provided to the subscriber and is not needed anymore for key storage, recovery, or back-up services, that the CA destroys this private key, including any copies, without undue delay.			☐ Pass ☐ Fail ☐ Not applicable

3.2.2 Subject key storage, backup and recovery

Concerning the secure storage, backup or recovery of subject keys, the following requirements apply:

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
3.2.2A1	1, 4	If private keys of subscribers/subjects are stored outside the security device (e.g. as backup), check that the private keys are processed with the same level of protection as defined in Section 3.2.1.			☐ Pass ☐ Fail ☐ Not applicable

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
3.2.2A2	1, 4	Check that any storage media containing backups of private keys are encrypted and secured against non-authorized usage.			☐ Pass ☐ Fail ☐ Not applicable

3.2.2.1 Subject key storage, backup and recovery services provided by CA (if supported)

Control procedures referenced in this Section refer to Section 7.14.2 of (ISO27099).

Please mark, if subject key storage, backup or recovery services are supported by the CA¹:

☐ Yes

☐ No

Note that (BSI-TR-03145-4) does not allow subject key storage, backup and recovery services provided by the CA.

If the CA provides key storage, backup or recovery services of subject keys, the following control procedures SHALL be fulfilled as requirements:

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
(1) from Section 7.14.2	1	Check that storing of CA private keys meets all the requirements as defined in section 7.14.2 of ISO 27099.			☐ Pass ☐ Fail ☐ Not applicable
(2) from Section 7.14.2	1	Check that, if the CA generates signing key pair (s) on behalf of a subscriber, the requirement of ISO 27099, section 7.14.2 (2) is fulfilled.			☐ Pass ☐ Fail ☐ Not applicable
(3) from Section 7.14.2	1	If the CA (or trusted service provider for key storage) generates public/private signing key pairs on behalf			☐ Pass ☐ Fail ☐ Not applicable

¹ Subject key storage, backup or recovery services by the CA are not supported by CAs within a CVCA PKI.

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
		of a subscriber, check that the requirements of section 7.14.2 (3) of ISO 27099 are met.			
(4) from Section 7.14.2	1	Check that all requirements as defined in section 7.14.2 (4) of ISO 27099 are fulfilled.			☐ Pass ☐ Fail ☐ Not applicable
(5) from Section 7.14.2	1	If the CA provides key storage, backup and recovery on behalf of the subject, check that controls as defined in section 7.14.2 (5) of ISO 27099 exists.			☐ Pass ☐ Fail ☐ Not applicable
(6) from Section 7.14.2	1	If the CA provides subject key archival check that requirement of section 7.14.2 (6) of ISO 27099 is fulfilled.			☐ Pass ☐ Fail ☐ Not applicable
(7) from Section 7.14.2	1	If the CA provides key recovery, check that the requirement as defined in section 7.14.2 (7) applies.			☐ Pass ☐ Fail ☐ Not applicable
(8) from Section 7.14.2	1	If the CA provides key recovery, check that the CA sends notification to the subscriber as defined in section 7.14.2 (8) of ISO 27099.			☐ Pass ☐ Fail ☐ Not applicable
(10) from Section 7.14.2	1	If the CA provides subject (confidentiality) key storage, check that all copies and fragments of the subject's private key are destroyed at the end of its life cycle.			☐ Pass ☐ Fail ☐ Not applicable
3.2.2.1A1	1	Check that any storage media containing backups of private keys is located in a physically and logically highly secured area. Check that access to this area is restricted to an appropriate set of persons which is clearly defined by their roles.			☐ Pass ☐ Fail ☐ Not applicable

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
		Check that the number of authorized persons is restricted, while ensuring staff availability to carry out these tasks.			

3.2.3 Hardware token life cycle management (if supported)

Control procedures referenced in this Section refer to Section 7.14.3 of (ISO27099).

Please mark, if the generation and dissemination of a “personalized” token is supported by the CA²:

☐ Yes

☐ No

Note that (BSI-TR-03145-4) does not allow that the CA generates a “personalized” token and disseminates it to the subscriber.

If Hardware token lifecycle management is provided by the CA, the following control procedures SHALL be fulfilled as requirements:

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
(2) from Section 7.14.3	1	For transport of hardware token between the card manufacturer and the card issuer check that requirement 7.14.3 (2) of ISO 27099 is fulfilled.			☐ Pass ☐ Fail ☐ Not applicable
(5) from Section 7.14.3	1	Check that hardware tokens are securely stored and under inventory control while under the control of the card issuer.			☐ Pass ☐ Fail ☐ Not applicable
(6) from Section 7.14.3	1	Check that the requirements as defined in section 7.14.3 (6) of ISO 27099 are fulfilled.			☐ Pass ☐ Fail ☐ Not applicable

² The generation and dissemination of a personalized token by the CA is not supported by CAs within a CVCA PKI.

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
(7) from Section 7.14.3	1	Check that hardware token personalization follows the processes and procedures and that all requirements as defined in section 7.14.3 (7) of ISO 27099 are fulfilled. The auditor must check all listed requirements of section 7.14.3 (7) separately, thus the enumeration from (a) to (f) of ISO 27099 is substituted by (i) to (vi) according to this TS.			☐ Pass ☐ Fail ☐ Not applicable
(8) from Section 7.14.3	1	Check that the card bureau or CA (or RA) logs hardware token preparation and personalization in an audit log.			☐ Pass ☐ Fail ☐ Not applicable
(11) from Section 7.14.3	1	Check that all requirements defined in section 7.14.3 (11) of ISO 27099 are fulfilled.			☐ Pass ☐ Fail ☐ Not applicable
(12) from Section 7.14.3	1	Check that the requirements for the initial activation data for hardware tokens as defined in section 7.14.3 (12) are fulfilled.			☐ Pass ☐ Fail ☐ Not applicable
(14) from Section 7.14.3	1	Check that the subject is provided with a mechanism that protects the access to the card data including the private keys stored on the hardware token during use by the subscriber (i.e. PIN access control mechanism – cardholder verification method).			☐ Pass ☐ Fail ☐ Not applicable

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
(15) from Section 7.14.3	1	Check that the subject private keys on the hardware token are not be exported to application for cryptographic functions, such as signing..			☐ Pass ☐ Fail ☐ Not applicable
(19) from Section 7.14.3	1	Check that processes and procedures for replacing lost or damaged hardware tokens are in existence and being followed.			☐ Pass ☐ Fail ☐ Not applicable
3.2.3A1	1	Check that the CA ensures that the hardware token (cryptographic hardware) is appropriate to the security requirements of the certificates throughout its life cycle and as defined in the CP.			☐ Pass ☐ Fail ☐ Not applicable
3.2.3A2	1	Check that the CA correctly assigns the hardware token and the public key from the hardware token to the subscriber's registration data.			☐ Pass ☐ Fail ☐ Not applicable
3.2.3A3	1	Check that the CA describes the dissemination procedure for hardware tokens in its Terms and Conditions.			☐ Pass ☐ Fail ☐ Not applicable
3.2.3A4	1	Check that the CA uses the registered subscriber data to ensure that the hardware token is disseminated to the correct subscriber.			☐ Pass ☐ Fail ☐ Not applicable
3.2.3A5	1	Check that the subscriber is obliged by the CA's Terms and Conditions to inform the CA when detecting a compromise of the PIN code during the activation procedure. Check that in this case the affected certificate is revoked.			☐ Pass ☐ Fail ☐ Not applicable

3.2.4 Subject key archival and destruction (if supported)

Control procedures referenced in this Section are based upon Section 7.13.5 of (ISO27099) but do not apply to the CA's own key but to the subject key.

Please mark, if archival or storage services of subject keys are provided by the CA³:

☐ Yes

☐ No

Note that (BSI-TR-03145-4) does not allow archival, storage and destruction services provided by the CA.

If the CA provides archival or storage services of subject keys, the following requirements concerning the archival and destruction of subject keys apply:

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
3.2.4A1	1	Check that subject private keys are archived with the same or a greater level of security as keys currently in use.			☐ Pass ☐ Fail ☐ Not applicable
3.2.4A2	1	Check that archived keys are only used when historical evidence requires validation.			☐ Pass ☐ Fail ☐ Not applicable
3.2.4A3	1	Check that the CA defines in its CPS how the subject's private key has to be destroyed (e.g. hardware token surrender, hardware token destruction or key overwrite).			☐ Pass ☐ Fail ☐ Not applicable
3.2.4A4	1	Check that all copies and fragments of the subject's private key are destroyed such that the private key cannot be retrieved.			☐ Pass ☐ Fail ☐ Not applicable
3.2.4A5	1	Check that the CA destroys the subject private key and all the backups after revocation or regular end of validity of the corresponding subject certificate.			☐ Pass ☐ Fail ☐ Not applicable

³ Subject key archival or storage by the CA are not supported by CAs within a CVCA PKI.

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
3.2.4A6	1	Check that destruction of subject keys is undertaken in a physically secured environment by authorized and trusted personnel under the principles of multiple control.			☐ Pass ☐ Fail ☐ Not applicable

4 Certificate life cycle management

In this section the requirements for the different tasks of a CA during the certificate life cycle are specified.

4.1 Subject registration

Control procedures referenced in this Section refer to Section 7.15.1 of (ISO27099). Concerning the subject registration the following control procedures SHALL be fulfilled as requirements:

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
(1) from Section 7.15.1	1, 4	Check that the CA verifies or requires that the RA verifies the credentials of a subject as defined in section 7.15.1 (1).			☐ Pass ☐ Fail ☐ Not applicable
(2) from Section 7.15.1	1, 4	Check that the CA or RA verifies the accuracy of the information included in the certificate request submitted by the requesting entity in accordance with the CP.			☐ Pass ☐ Fail ☐ Not applicable
(3) from Section 7.15.1	1, 4	Check that the CA or RA checks the certificate request for errors or omissions in accordance with the CP.			☐ Pass ☐ Fail ☐ Not applicable
(4) from Section 7.15.1	1, 4	The CA must check that the end entity signing request is submitted securely and fulfils the requirements as defined in section 7.15.1 (4).			☐ Pass ☐ Fail ☐ Not applicable
(5) from Section 7.15.1	1, 4	Check that encryption and access controls are used as defined in section 7.15.1 (5) of ISO 27099.			☐ Pass ☐ Fail ☐ Not applicable
(6) from Section 7.15.1	1, 4	Check that the CA or RA, at the point of registration, informs the subject or subscriber about the terms and			☐ Pass ☐ Fail ☐ Not applicable

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
		condition about using the certificates as defined in section 7.15.1 (6) of ISO 27099.			
(7) from Section 7.15.1	1, 4	Check that the identification and authentication of a subject is done first, before issuing certificate, as defined in section 7.15.1 (7) of ISO 27099.			☐ Pass ☐ Fail ☐ Not applicable
(8) from Section 7.15.1	1, 4	Check that the RA or CA keeps registration and related administrative data as defined in section 7.15.1 (8) of ISO 27099.			☐ Pass ☐ Fail ☐ Not applicable
(10) from Section 7.15.1	1, 4	Check that there is evidence of the subjects' agreement to the terms and conditions.			☐ Pass ☐ Fail ☐ Not applicable
(11) from Section 7.15.1	1, 4	Check that the CA (or RA) records the success or failure of the registration event in an audit log.			☐ Pass ☐ Fail ☐ Not applicable
(12) from Section 7.15.1	1, 4	Check that the CA stores the certificate enrolment data in a database, that follows the requirements as defined in section 7.15.1 (12) of ISO 27099.			☐ Pass ☐ Fail ☐ Not applicable
(13) from Section 7.15.1	1, 4	Check that the CA or RA ensures that the 'Identification and registration' process is secure. In particular, check that all transfers of registration and identification data, whether inside or outside the CA or RA, are protected against eavesdropping and manipulation.			☐ Pass ☐ Fail ☐ Not applicable
4.1A1	1, 4	Check that the formal process-flow including the interfaces for requesting the registration and/or providing information by the subscriber are clearly defined and verified by the CA or RA.			☐ Pass ☐ Fail ☐ Not applicable

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
4.1A2	1, 4	Check that the CA obliges subscribers to notify the CA immediately about any change of their registration data. Check that the CA requires a confirmation from the subscriber that the registration data is still valid at least every [assignment: number of months] months.			☐ Pass ☐ Fail ☐ Not applicable
4.1A3	1, 4	Check that the CA verifies the information identifying the subscribers and the physical existence directly or indirectly using appropriate measures. Check that the physical address or other appropriate attributes for contact are verified.			☐ Pass ☐ Fail ☐ Not applicable
4.1A4	1, 4	Check that the CA defines clearly the set of information identifying the subscriber. If the subject differs from the subscriber, check that additional information (e.g. evidence of legitimation to act on behalf of subject) are provided and checked. In case of a physical person associated with a legal person, check that this association is verified.			☐ Pass ☐ Fail ☐ Not applicable
4.1A5	1, 4	Check that the CA checks its database to determine if a subject has registered before so that multiple identities of a subject are linked within the registration database and can be suspended at once or prevented totally if required by the Terms and Conditions.			☐ Pass ☐ Fail ☐ Not applicable
4.1A6	1	Check that the CA ensures, that the requesting subject is identified unambiguously before starting the certificate generation process.			☐ Pass ☐ Fail ☐ Not applicable

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
	4	Check that the CA ensures, that the requesting subject is identified unambiguously before starting the certificate generation process. Check that the CA verifies certificate requests as specified in the corresponding CP. Check in particular, that the CA validates the signatures on certificate requests for successive certificate.			☐ Pass ☐ Fail ☐ Not applicable

4.2 Certificate renewal (if supported)

Control procedures referenced in this Section refer to Section 7.15.2 of (ISO27099).

Please mark, if certificate renewal is provided by the CA

☐ Yes

☐ No

Note that (BSI-TR-03145-4) does not allow renewal of certificates.

If certificate renewal is provided the following control procedures SHALL be fulfilled as requirements:

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
(2) from Section 7.15.2	1	Check that the CA ensures that the requirements on secure submission of renewal request is done as defined section 7.15.2 (2) of ISO 27099.			☐ Pass ☐ Fail ☐ Not applicable

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
(3) from Section 7.15.2	1	Check that the CA issues a new certificate using subject's previous certified public key only when all the requirements of section 7.15.2 (3) of ISO 27099 are fulfilled. Check in particular, that the CA does not issue new certificate if the points defined in section 7.15.2 (3) of ISO 27099 are valid. The auditor must check all listed requirements of section 7.15.2 (3) separately, thus the enumeration from (a) to (c) of ISO 27099 is substituted by (i) to (iii) according to this TS.			☐ Pass ☐ Fail ☐ Not applicable
(4) from Section 7.15.2	1	Check that the CA or the RA processes the certificate renewal data as defined in section 7.15.2 (4) of ISO 27099.			☐ Pass ☐ Fail ☐ Not applicable
(5) from Section 7.15.2	1	Check that the CA verifies the existence and validity of the certificate to be renewed. Check that renewal is not permitted unless the existing certificate status is live (i.e. not revoked or suspended).			☐ Pass ☐ Fail ☐ Not applicable
(6) from Section 7.15.2	1	Check that the CA or the RA verifies that the requirements as defined in section 7.15.2 (6) of ISO 27099 is fulfilled.			☐ Pass ☐ Fail ☐ Not applicable
(8) from Section 7.15.2	1	Check that the CA records the renewal actions in an audit log.			☐ Pass ☐ Fail ☐ Not applicable
(9) from Section 7.15.2	1	Check that the certificate renewal request is checked for errors or omissions by the CA or RA.			☐ Pass ☐ Fail ☐ Not applicable

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
(12) from Section 7.15.2	1	Check that the new certificate is made available to the end entity by the issuing CA in accordance with the requirements of the corresponding CP.			☐ Pass ☐ Fail ☐ Not applicable
(13) from Section 7.15.2	1	Check that the CA defines Terms and Conditions in which cases renewal may be allowed			☐ Pass ☐ Fail ☐ Not applicable
(14) from Section 7.15.2	1	Check that all requirements as defined in section 7.15.2 (14) of ISO 27099 are fulfilled.			☐ Pass ☐ Fail ☐ Not applicable
4.2A1	1	Check that the CA checks carefully, if the renewal of a certificate is necessary. Check that the need for a renewal instead of re-keying demanded by the business case is balanced with the security risk of the weakened key pair, the validity period of the certificate and the used algorithms. In case of doubt, check that re-keying of the certificate is done.			☐ Pass ☐ Fail ☐ Not applicable
4.2A2	1	For the case of expiring certificates, check that the CA defines in the CP and/or CPS that a request for the renewal of a certificate SHALL be submitted at least [assignment: number of days or weeks] before the previous certificate expires. Check that the CA is able to generate the new certificate within the defined timeframe.			☐ Pass ☐ Fail ☐ Not applicable
4.2A3	1	Check that the CA defines clearly in its Terms and Conditions in which cases renewal may be allowed.			☐ Pass ☐ Fail ☐ Not applicable

4.3 Certificate rekey

Control procedures referenced in this Section refer to Section 7.15.3 of (ISO27099).

Note that (BSI-TR-03145-4) does only allow the rekeying of CV certificates but not the rekeying of MDS certificates.

Concerning rekeying of a certificate the following control procedures SHALL be fulfilled as requirements:

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
(1) from Section 7.15.3	1, 4	Check that the CA ensures that the rekeying request is secure transmitted and authenticated as defined in section 7.15.3 (1).			☐ Pass ☐ Fail ☐ Not applicable
(2) from Section 7.15.3	1, 4	Check that the requirement as defined in section 7.15.3 (2) of ISO 27099 is fulfilled.			☐ Pass ☐ Fail ☐ Not applicable
(3) from Section 7.15.3	1, 4	Check that the CA or the RA checks the certificate rekey request for errors or omissions.			☐ Pass ☐ Fail ☐ Not applicable
(5) from Section 7.15.3	1, 4	Check that prior to the rekeying of existing certificates all the requirements as listed in section 7.15.3 (5) of ISO 27099 are verified. The auditor must check all listed requirements of section 7.15.3 (5) separately, thus the enumeration from (a) to (f) of ISO 27099 is substituted by (i) to (vi) according to this TS.			☐ Pass ☐ Fail ☐ Not applicable
(8) from Section 7.15.3	1, 4	Check that the CA defines the terms and conditions under which rekeying may be permitted.			☐ Pass ☐ Fail ☐ Not applicable
4.3A1	1	For the case of expiring certificates, check that the CA defines in the CP and/or CPS that a request for the rekeying of a certificate SHALL be submitted at least			☐ Pass ☐ Fail ☐ Not applicable

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
		[assignment: number of days or weeks] before the previous certificate expires. Check that the CA is able to generate the new certificate within the defined timeframe.			
	4	Check that for the case of expiring certificates, the CA defines in the CP and/or CPS that a request for the rekeying of a certificate is submitted according to the time frames defined in the CA's CP. Check that the CA is able to generate the new certificate within the defined timeframe.			☐ Pass ☐ Fail ☐ Not applicable
4.3A2	1, 4	Check that the CA enforces the use of a newly generated key pair.			☐ Pass ☐ Fail ☐ Not applicable

4.4 Certificate issuance

Control procedures referenced in this Section refer to Section 7.15.4 of (ISO27099). Concerning certificate issuance the following control procedure SHALL be fulfilled as requirement:

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
(4) from Section 7.15.4	1	Check that the requirement of section 7.15.4 (4) of ISO 27099 is fulfilled.			☐ Pass ☐ Fail ☐ Not applicable
	4	Not applicable to CAs affected by (BSI-TR-03145-4)			☐ Pass ☐ Fail ☒ Not applicable

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
4.4A1	1, 4	Check that the CA does not allow issuance of identical certificate attributes for two different key pairs.			☐ Pass ☐ Fail ☐ Not applicable
4.4A2	1	Check that certificates include the following attributes: • identification of the CA (cf. “issuer” according to (RFC5280)), • name of the subscriber or the identifiable subject, • additional relevant attributes of the CA or subject/subscriber, • public key corresponding to the private key under the subscriber control, • period of validity, • the certificate serial number, • the electronic signature of the issuing authority, • limitation of the scope of the certificate, • limitations on transactions, • information about the cryptographic algorithms of the issuing authority's signature and of the public key of the subscriber. Check that these attributes are verified by the CA.			☐ Pass ☐ Fail ☐ Not applicable

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
	4	Check that certificates (german: Berechtigungszertifikate) include the following attributes: • Certificate Authority Reference , • Certificate Holder Reference , • type of certificate, • public key corresponding to the private key under the subscriber control, • period of validity, • the sequence number of the certificate, • the electronic signature of the issuing authority, • access rights • certificate extensions (if applicable). Check that these attributes are verified by the CA.			☐ Pass ☐ Fail ☐ Not applicable
	4	Check that MDS Certificates include the following attributes: • Distinguished Name of Issuer, • Distinguished Name of Subject, • public key corresponding to the private key under the subscriber control, • period of validity, • the certificate serial number,			☐ Pass ☐ Fail ☐ Not applicable

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
		- the electronic signature of the issuing authority, - certificate extensions (if applicable). Check that these attributes are verified by the CA.			
4.4A3	1, 4	Check that the CA is able for all disseminated certificates to associate unambiguously a certificate to the subject the respective certificate has been disseminated to.			☐ Pass ☐ Fail ☐ Not applicable
4.4A4	1	Check that the CA differentiates between private key usage and validity period of the public key.			☐ Pass ☐ Fail ☐ Not applicable
	4	Not applicable to CAs affected by (BSI-TR-03145-4)			☐ Pass ☐ Fail ☒ Not applicable

4.5 Certificate distribution

Control procedures referenced in this Section refer to Section 7.15.5 of (ISO27099). Concerning the distribution of certificates, the following control procedures SHALL be fulfilled as requirements:

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
(1) from Section 7.15.5	1, 4	Check that the CA makes the issued certificates available to relevant parties as defined in section 7.15.5 (1) of ISO 27099.			☐ Pass ☐ Fail ☐ Not applicable

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
(2) from Section 7.15.5	1, 4	Check that only authorized CA personal is allowed to administer its repository or to administer alternative distribution mechanisms.			☐ Pass ☐ Fail ☐ Not applicable
(3) from Section 7.15.5	1, 4	Check that requirement of section 7.15.5 (3) is fulfilled.			☐ Pass ☐ Fail ☐ Not applicable

4.5.1 Directory Service⁴ (if supported)

If a directory service is supported, then following requirements apply:

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
4.5.1A1	1	Check that the Directory Service provides a searchable repository that contains all certificates that are issued by this CA and their certificate status information.			☐ Pass ☐ Fail ☐ Not applicable
	4	Check that the CA provides a searchable repository that contains all certificates that are issued by this CA and their certificate status information.			☐ Pass ☐ Fail ☐ Not applicable
4.5.1A2	1	Check that the publication of a certificate, i.e. the delay between issuance of a certificate and its availability on the directory service to all relying parties, is at most [assignment: number of hours/days].			☐ Pass ☐ Fail ☐ Not applicable

⁴ For a certification according to (BSI-TR-03145-4) the requirements ascribed to a directory service SHALL be fulfilled by a non-public repository which is operated and maintained by the CA.

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
	4	Not applicable to CAs affected by (BSI-TR-03145-4)			☐ Pass ☐ Fail ☒ Not applicable
4.5.1A3	1, 4	Check that the Directory Service provides secure communication and adequate controls in order to prevent unauthorized entities from adding, modifying, or deleting repository entries. Check that the exact control mechanisms is part of the respective CPS.			☐ Pass ☐ Fail ☐ Not applicable
4.5.1A4	1	Check that the Directory Service grants access to all relevant information to the relying parties.			☐ Pass ☐ Fail ☐ Not applicable
	4	Check that the Repository is not publicly accessible.			☐ Pass ☐ Fail ☐ Not applicable

4.6 Certificate changeover (if supported)

Please mark, if the root-CA uses link certificates

☐ Yes

☐ No

☐ Not applicable⁵

Note that concerning (BSI-TR-03145-4) the requirements from this Section are mandatory for certificate changeover within a CVCA PKI, except MDS certificates within the CVCA-eID PKI.

If a certificate changeover by means of link certificates is supported by a root-CA, the following requirements apply:

⁵ e.g., because the audited CA is a sub-CA

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
4.6A1	1, 4	Check for a root-CA changeover, that the root-CA generates two certificates: a self-signed successor certificate and a link certificate. Check that the link certificate contains the public key and the attributes of the successor certificate and is signed with the private key of the currently valid root-CA certificate. If the root-CA implements a directory service, check that these two certificates are published on the root-CA's directory service to enable the verification of the integrity and authenticity of the successor root-CA certificate.			☐ Pass ☐ Fail ☐ Not applicable
4.6A2	1	Check that the root-CA changeover is performed with a preloading phase of at least [assignment: number of days/months]. Check that the successor certificate of the CA is generated accordingly to that preloading phase before its validity starts. Check that during this preloading phase the successor certificate and the link certificate, if supported, are securely distributed to all relying parties.			☐ Pass ☐ Fail ☐ Not applicable
	4	Not applicable to CAs affected by (BSI-TR-03145-4)			☐ Pass ☐ Fail ☒ Not applicable

Concerning the secure transition from a CA certificate to the succeeding CA certificate the following requirements apply for both, root-CA and sub-CA:

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
4.6A3	1	Check that a CA changeover is performed with an overlap time of at least [assignment: number of days/months] up to at most [assignment: number of days/months] in order to ensure a secure transition from the current to the successor CA certificate. Check that the overlap time starts at the same time as the validity of the successor certificate starts.			☐ Pass ☐ Fail ☐ Not applicable
	4	Check that the CA changeover is performed with an overlap time in compliance with the CA's CP in order to ensure a secure transition from the current to the successor CA certificate. Check that the overlap time starts at the same time as the validity of the successor certificate starts.			☐ Pass ☐ Fail ☐ Not applicable
4.6A4	1, 4	Check that after expiration of the overlap time, the private key including backup keys of the current CA certificate are securely deleted.			☐ Pass ☐ Fail ☐ Not applicable
4.6A5	1, 4	Check that the CA uses its newest private key for issuing certificates. Check that a CA's private key is not used anymore for issuing certificates, once a successor certificate becomes valid. Check that at any point in time there is exactly one private key in usage for issuing certificates.			☐ Pass ☐ Fail ☐ Not applicable
4.6A6	1	Check that the CA uses its newest private key for signing its Certificate Revocation List.			☐ Pass ☐ Fail ☐ Not applicable

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
		Check that a CA's private key is not used anymore for signing CRLs, once a successor certificate becomes valid. Check that at any point in time there is only one private key in usage for signing the Root CA's or Sub CA's Certificate Revocation List.⁶			
	4	Not applicable to CAs affected by (BSI-TR-03145-4)			☐ Pass ☐ Fail ☒ Not applicable
4.6A7	4	Check that the CA provides an appropriate process for re-keying of a certificate if the process is requested by the subscriber or started by the CA. Check that the CA ensures that the request is processed in a timely manner.			☐ Pass ☐ Fail ☐ Not applicable

4.7 Certificate revocation

Control procedures referenced in this Section refer to Section 7.15.6 of (ISO27099).

Note that only MDS certificates within the CVCA-eID PKI are revoked. Therefore, the requirements in this section apply to MDS certificates within the CVCA-eID PKI only.

Concerning the revocation of certificates the following control procedures SHALL be fulfilled as requirements:

⁶ Note that although the CRL is always signed with the newest private key of the CA, the CRL can include revoked certificates that are issued by this CA with its newest private key as well as revoked certificates that are issued by this CA with one of its earlier private keys.

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
(1) from Section 7.15.6	1, 4	Check that the CA provides a means to facilitated secure and authenticated revocation as defined in section 7.15.6 (1) of ISO 27099.			☐ Pass ☐ Fail ☐ Not applicable
(2) from Section 7.15.6	1, 4	Check that the CA ensures that the revocation request is securely submitted. Check that the revocation request is from an authorised entity.			☐ Pass ☐ Fail ☐ Not applicable
(4) from Section 7.15.6	1, 4	Check that all certificate revocation requests and outcomes are recorded in an audit log as defined in section 7.15.6 (4) of ISO 27099.			☐ Pass ☐ Fail ☐ Not applicable
(6) from Section 7.15.6	1, 4	Even if certificate renewal is supported, check that a revoked certificate is never reinstated			☐ Pass ☐ Fail ☐ Not applicable
(7) from Section 7.15.6	1, 4	Check that the CA ensures a notification of a subject or subscriber is done in case of certificate revocation as defined in section 7.15.6 (7) of ISO 27099.			☐ Pass ☐ Fail ☐ Not applicable
(8) from Section 7.15.6	1, 4	Check that the system hosting the revocation information fulfils the requirements as defined in section 7.15.6 (8) of ISO 27099. Check that the CA analyses the risk of a system failure and attacks against the system, taking the assumed traffic into account.			☐ Pass ☐ Fail ☐ Not applicable
(9) from Section 7.15.6	1, 4	Check that the revocation information is secured as defined in section 7.15.6 (9) of ISO 27099.			☐ Pass ☐ Fail ☐ Not applicable

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
(10) from Section 7.15.6	1	Check that the CA maintains controls to revoke certificates and publish appropriate information about the revoked certificates.			☐ Pass ☐ Fail ☐ Not applicable
	4	Check that the CA maintains controls to revoke MDS certificates and publish appropriate information about revoked MDS certificates.			☐ Pass ☐ Fail ☐ Not applicable
4.7A1	1, 4	Check if a legitimate revocation request is received that the CRL, OCSP responder (if supported), or other certificate status information mechanisms are updated by the CA in the respective time frames specified within the CP.			☐ Pass ☐ Fail ☐ Not applicable
4.7A2	1, 4	Check that the complete revocation process (i.e. the delay between a revocation request or report and the availability of the revocation status information to all relying parties) is at most [assignment: number of hours] hours.			☐ Pass ☐ Fail ☐ Not applicable
4.7A3	1, 4	Check that certificate status information are backed up to a physically separated server to avoid the loss of data.			☐ Pass ☐ Fail ☐ Not applicable
4.7A4	1, 4	Check that the integrity of the revocation information, both of the original and the back-ups, are secured by appropriate cryptographic measures.			☐ Pass ☐ Fail ☐ Not applicable
4.7A5	1, 4	Check that the service processing the revocation of certificates ensures the processing of inquiries and updates within [assignment: number of hours] hours.			☐ Pass ☐ Fail ☐ Not applicable

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
4.7A6	1, 4	Check that the CA provides a service receiving the revocation or suspension request by subscribers or third parties. Check that this service is available as required by the application context or business case, respectively.			☐ Pass ☐ Fail ☐ Not applicable
4.7A7	1, 4	Check that the CA documents and archives each revocation request and actually performed revocation in a comprehensible way. Check that this documentation and archiving includes at least: • entity that applied for revocation of a certificate, • name of revoked subject if present and known at time of revocation, • serial number of revoked certificate if present and known at time of revocation, • reasonable evidence for the legitimacy of the revoking party, • date and time of revocation, • date and time of invalidity, and • revocation reason.			☐ Pass ☐ Fail ☐ Not applicable
4.7A8	1, 4	Check that after a revocation of a subject's certificate, a new certificate for this subject has to be requested following the process of initial application.			☐ Pass ☐ Fail ☐ Not applicable
4.7A9	1, 4	Check that after a revocation of a subject's certificate, the CA creates new certificates for the subject with a new key pair.			☐ Pass ☐ Fail ☐ Not applicable

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
4.7A10	4	Check that revocation lists of MDS certificates are backed up to a physically separated server to avoid the loss of data.			☐ Pass ☐ Fail ☐ Not applicable
4.7A11	4	Check that the integrity of the revocation information is secured by appropriate means.			☐ Pass ☐ Fail ☐ Not applicable
4.7A12	4	Check that the service processing the revocation of certificates ensures the processing of inquiries and updates as specified in the CA's CP.			☐ Pass ☐ Fail ☐ Not applicable
4.7A13	4	Check that the CA documents and archives each revocation request and actually performed revocation in a comprehensible way. Check that this documentation and archiving includes at least: • entity that applied for revocation of a certificate, • name of revoked subject if present and known at time of revocation, • serial number of revoked certificate if present and known at time of revocation, • reasonable evidence for the legitimacy of the revoking party, • date and time of revocation, • date and time of invalidity, and • revocation reason.			☐ Pass ☐ Fail ☐ Not applicable

4.8 Certificate suspension (if supported)

Control procedures referenced in this Section refer to Section 7.15.7 of (ISO27099).

Please mark if the CA supports suspension of

- ☐ subscribers
- ☐ certificates
- ☐ both
- ☐ none

Note that concerning (BSI-TR-03145-4) the suspension of subscribers SHALL be provided by CAs within the CVCA-PKI.

If suspension is supported by the CA, the following control procedures SHALL be fulfilled as requirements:

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
(1) from Section 7.15.7	1, 4	Check that the CA defines and implements a process for suspension requests as defined in section 7.15.7 (1) of ISO 27099. Check that the security and authenticity of the suspension request is ensured as defined in section 7.15.7 (1) of ISO 27099. The auditor must check all listed requirements of section 7.15.7 (1) separately, thus the enumeration from (a) to (c) of ISO 27099 is substituted by (i) to (iii) according to this TS.			☐ Pass ☐ Fail ☐ Not applicable
(2) from Section 7.15.7	1, 4	Check that the CA requirement according to section 7.15.7 (2) of ISO 27099 is fulfilled.			☐ Pass ☐ Fail ☐ Not applicable
(3) from Section 7.15.7	1, 4	Check that notification by the CA or RA is done as defined in section 7.15.7 (3) of ISO 27099.			☐ Pass ☐ Fail ☐ Not applicable

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
(4) from Section 7.15.7	1, 4	Check that requests for certificate suspension are processed and validated in accordance with CP's requirements.			☐ Pass ☐ Fail ☐ Not applicable
(5) from Section 7.15.7	1	Check that the CA updates the certificate revocation list (CRL) as defined in section 7.15.7 (5) of ISO 27099. Check that changes in certificate status are completed in a time frame determined by the CP.			☐ Pass ☐ Fail ☐ Not applicable
	4	Check that the CA updates the suspension status information when a certificate is suspended.			☐ Pass ☐ Fail ☐ Not applicable
(9) from Section 7.15.7	1, 4	Check that requirement as defined in section 7.15.7 (9) is fulfilled.			☐ Pass ☐ Fail ☐ Not applicable
	4	Check that the CA updates the suspension status information upon the lifting of a certificate suspension in accordance with the CA's CP.			☐ Pass ☐ Fail ☐ Not applicable
(10) from Section 7.15.7	1, 4	Check that the CA verifies, or requires the RA to verify, the identity and authority of the entity requesting the lifting of a certificate suspension.			☐ Pass ☐ Fail ☐ Not applicable
(13) from Section 7.15.7	1	Check that in case a legitimate suspension request is received the suspension status information must be handled as defined in section 7.15.7 (13) of ISO 27099.			☐ Pass ☐ Fail ☐ Not applicable
	4	Check that the CA processes and updates the suspension status information in a period of [assignment: number of hours] hours in case of a suspension.			☐ Pass ☐ Fail ☐ Not applicable

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
(14) from Section 7.15.7	1	Check that requirement according section 7.15.7 (14) of ISO 27099 is fulfilled.			☐ Pass ☐ Fail ☐ Not applicable
	4	Check that the CA ensures that the suspension status information is secured against failure, attacks and unauthorized modification. Check that the CA analyses the risk of a server failure and attacks against the server. Check that the IT infrastructure is deployed redundantly, if neccessary.			☐ Pass ☐ Fail ☐ Not applicable
(15) from Section 7.15.7	1, 4	Check that the system hosting the suspension status information is protected against both system failure and attacks. Check that the CA analyses the risk of system failures as well as attacks against the system as defined in section 7.15.7 (15) of ISO 27099.			☐ Pass ☐ Fail ☐ Not applicable
4.8A1	1	Check that certificate suspension entries remain on the CRL until the expiration of the underlying certificate or the expiration of the suspension, whichever is first. Check if the CP specifies a maximum number for how often the certificate status may be suspended and a maximum time-period for the suspension status. In this case, check that the CA complies to its CP.			☐ Pass ☐ Fail ☐ Not applicable
	4	Not applicable to CAs affected by (BSI-TR-03145-4)			☐ Pass ☐ Fail ☒ Not applicable
4.8A2	1	Check that the complete suspension process (i.e. the delay between a suspension request or report and the			☐ Pass ☐ Fail

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
		availability of the suspension status information to all relying parties) is at most [assignment: number of minutes] minutes.			☐ Not applicable
	4	Check that the complete suspension process (i.e. the delay between a suspension request or report and the availability of the suspension status information) is at most [assignment: number of minutes] minutes.			☐ Pass ☐ Fail ☐ Not applicable
4.8A3	4	Check that the CA ensures that suspended subscribers will not receive any certificates as long as the suspension is active.			☐ Pass ☐ Fail ☐ Not applicable
4.8A4	4	Check that the CA defines an appropriate procedure for the suspension started by an authorized subscriber suspension. Check that the involved parties and suspension reasons are clearly defined. Check that the CA ensures: (i) the identification of persons/institutions with legitimate claim to apply for suspension of a subscriber: the subscriber/certificate holder, [assignment: list of further persons/institutions], (ii) the identification of reasons for a suspension: private key of certificate compromised, incorrect information on certificate, security incident on the IT systems of the certificate holder/subscriber, subscriber not fulfilling Terms and Conditions of the CA, [assignment: other reasons for suspension],			☐ Pass ☐ Fail ☐ Not applicable

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
		(iii) [assignment: the transmission path and record of the suspension], (iv) [assignment: additional requirements for a successful suspension], (v) The suspension of a subscriber may only be cancelled, if the cause for the suspension has been solved.			
4.8A5	4	Check that the CA ensures that suspension information are up-to-date and accessible by the registration and the certification processes as well.			☐ Pass ☐ Fail ☐ Not applicable

4.9 Revocation status information service

Control procedures referenced in this Section refer to Section 7.15.8 of (ISO27099).

Please mark, how revocation status information are provided by the CA (multiple selection possible)

- ☐ CRL
☐ OCSP
☐ others: _____

Note that concerning (BSI-TR-03145-4) only MDS certificates within the CVCA-eID PKI are revoked. Therefore, the requirements in this section apply to MDS certificates within the CVCA-eID PKI only.

Concerning the revocation status information service the following control procedure SHALL be fulfilled as requirements:

Requirement	TR-Part	Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
(1) from Section 7.15.8	1, 4	Check that the CA makes certificate status information available to all relevant parties via an mechanism as defined in section 7.15.8 (1) of ISO 27099.			☐ Pass ☐ Fail ☐ Not applicable
(2) from Section 7.15.8	1, 4	If CRLs are used: Check that the CA digitally signs each CRL so that all requirements of section 7.15.8 (2) of ISO 27099 are fulfilled.			☐ Pass ☐ Fail ☐ Not applicable
(3) from Section 7.15.8	1, 4	If CRLs are used: Check that the CA issues CRLs at regular intervals as defined in section 7.15.8 (3) of ISO 27099.			☐ Pass ☐ Fail ☐ Not applicable
(4) from Section 7.15.8	1, 4	If CRLs are used: Check that at a minimum, that a CRL entry identifying the revocation of certificates remains on the CRL until the end of certificate's validity period. Check if a retrospective view of a certificate status, at a given point in time, is required. If this is the case, check that CRL entries are held beyond the life of a certificate validity period to prove its validity at the time of use.			☐ Pass ☐ Fail ☐ Not applicable
(5) from Section 7.15.8	1	If CRLs are used: If certificate suspension is used, check that the requirements according to section 7.15.8 (5) of ISO 27099 are fulfilled.			☐ Pass ☐ Fail ☐ Not applicable
	4	Not applicable to CAs affected by (BSI-TR-03145-4)			☐ Pass ☐ Fail

					☒ Not applicable
(6) from Section 7.15.8	1, 4	If CRLs are used: Check that the CRL are retained and archived as defined in section 7.15.8 (6) of ISO 27099.			☐ Pass ☐ Fail ☐ Not applicable
(7) from Section 7.15.8	1, 4	If CRLs are used: Check that all requirements of section 7.15.8 (7) of ISO 27099 are fulfilled, when issuing CRLs.			☐ Pass ☐ Fail ☐ Not applicable
(9) from Section 7.15.8	1	If online certificate status mechanisms (e.g. OCSP) are used: Check that all response messages are digitally signed and include all required data as defined within the underlying CP.			☐ Pass ☐ Fail ☐ Not applicable
	4	Not applicable to CAs affected by (BSI-TR-03145-4)			☐ Pass ☐ Fail ☒ Not applicable
(10) from Section 7.15.8	1	If online certificate status mechanisms (e.g. OCSP) are used: Check that the requirements as defined in 7.15.8 (10) of ISO 27099 are fulfilled.			☐ Pass ☐ Fail ☐ Not applicable
	4	Not applicable to CAs affected by (BSI-TR-03145-4)			☐ Pass ☐ Fail ☒ Not applicable
4.9A1	1	Check that the CA ensures that the revocation information is continuously available and accessible to the relying parties.			☐ Pass ☐ Fail ☐ Not applicable
	4	Check that the CA ensures that the status information of certificates or subscribers is continuously available and accessible to the relevant parties.			☐ Pass ☐ Fail ☐ Not applicable

4.9A2	1, 4	Check that the CA ensures that the provided revocation information is up to date.			☐ Pass ☐ Fail ☐ Not applicable
4.9A3	1, 4	Check that the Servers hosting the maintained revocation information are hardened against failure and attacks. Check that the hardening against failure and attacks is based on the risk analysis.			☐ Pass ☐ Fail ☐ Not applicable

4.10 Validation Model

Concerning the validation model the following requirements apply:

Requirement		Inspection	CA Documentation	Measures identified by auditor	Verdict and Explanations by the Auditor
4.10A1	1, 4	Check that within the whole PKI in which the CA is active, one validation model is consistently applied. Check that the CA ensures a consistent application of the validation model for all of its operations such that the validity periods of all certificates in a certificate chain are chosen according to the chosen validation model.			☐ Pass ☐ Fail ☐ Not applicable
4.10A2	1	Check that the Shell Model is used. If the CA uses a different validation model, check that the CA justifies its reasons.			☐ Pass ☐ Fail ☐ Not applicable
	4	Check that the Shell Model is used.			☐ Pass ☐ Fail ☐ Not applicable

Bibliography

- BSI-TR-02102. *Bundesamt für Sicherheit in der Informationstechnik: Kryptographische Verfahren: Empfehlungen und Schlüssellängen*. kein Datum.
- BSI-TR-03107. *Bundesamt für Sicherheit in der Informationstechnik: Elektronische Identitäten und Vertrauensdienste im E-Government, Teil 1: Vertrauensniveau und Mechanismen*. kein Datum.
- BSI-TR-03110. „Bundesamt für Sicherheit in der Informationstechnik: Advanced Security Mechanisms for Machine Readable Travel Documents and eIDAS token.“ kein Datum.
- BSI-TR-03116. *Bundesamt für Sicherheit in der Informationstechnik: Kryptographische Vorgaben für Projekte der Bundesregierung*. kein Datum.
- BSI-TR-03116-2. „Bundesamt für Sicherheit in der Informationstechnik: Kryptographische Vorgaben für Projekte der Bundesregierung, Teil 2: Hoheitliche und eID-Dokumente.“ kein Datum.
- BSI-TR-03145. „Bundesamt für Sicherheit in der Informationstechnik: Secure CA operation.“ kein Datum.
- BSI-TR-03145-1. „Bundesamt für Sicherheit in der Informationstechnik: Secure CA operation, Part 1: Generic requirements for a Certification Authority in a Public Key Infrastructure with security level 'high'.“ kein Datum.
- BSI-TR-03145-4. „Bundesamt für Sicherheit in der Informationstechnik: Secure CA operation.“ Part 4: Specific requirements for a Certification Authority in a Public Key Infrastructure for the Extended Access Control of the German Official Travel Documents according to BSI TR-03110.
- BSI-TR-03145-5. „Bundesamt für Sicherheit in der Informationstechnik: Secure CA operation.“ Part 5: Specific requirements for a Public Key Infrastructure for Technical Security Systems.
- ETSI102042. „ETSI TS 102 042: Policy requirements for certification authorities issuing public key certificates.“ kein Datum.
- ISO15408. „ISO/IEC 15408: Information technology -- Security techniques -- Evaluation criteria for IT security.“ kein Datum.
- ISO27001. „ISO/IEC 27001: Information security management systems – Requirements.“ 2022.
- ISO27099. „ISO/IEC 27099: Information technology – Public key infrastructure – Practices and policy framework.“ 2022.
- KLSR. „Bundesamt für Sicherheit in der Informationstechnik: Key Lifecycle Security Requirements.“ kein Datum.
- RFC2119. Bradner, S.: *Key words for use in RFCs to Indicate Requirement Levels*. <https://datatracker.ietf.org/doc/html/rfc2119>: IETF, kein Datum.
- RFC5280. Cooper, D.; Santesson, S.; Farrell, S.; Boeyen, S.; Housley, R.; Polk, W.: *RFC5280 Internet X.509 Public Key Infrastructure Certificate and Certificate Revocation List (CRL) Profile*. <https://datatracker.ietf.org/doc/html/rfc5280>: IETF, kein Datum.